OT Top 10

The Top 10 Operational Technology Security Risks

2025 Edition



PROJECT LEADERS

Andreas Happe
Felix Eberstaller
Simon Rommer
Siegfried Hollerer

ot.owasp.org



OT Top 10

Operational Technology Security Risks

OWASP Operational Technology (OT) Top 10, 2025 Edition

Version: 2025.0.0-127-g3616452

Available online at https://ot.owasp.org. This is a living document and is updated as the OT threat landscape evolves.

Part of the OWASP OT Top 10 Project:
https://owasp.org/www-project-operational-technology-top-10/

Project leaders (in alphabetical order): Andreas Happe, Felix Eberstaller, Simon Rommer, Siegfried Hollerer.

Copyright © The OWASP Foundation

This work is licensed under the Creative Commons Attribution-ShareAlike 4.0 International License (CC BY-SA 4.0). For any reuse or distribution, you must make the license terms of this work clear to others. OWASP® is a registered trademark of the OWASP Foundation, Inc.

Contents

I. Introduction 1

OWASP OT Top 10 2
- Aim & Objective . . . 3
- Scope . . . 3
- Target Audience . . . 3
- How to Use This Document . . . 3
- The Top 10 List . . . 4
- Project Leaders (in Alphabetical Order) . . . 4
- Copyright and License . . . 4

Summary 5
- The Top 10 at a Glance . . . 5

II. Operational Technology (OT) 7

Defining the Domain: CPS, OT, and ICS 8
- The Purdue Model: Organizing Systems by Function . . . 9
- The IT/OT Convergence: Defining Functional Context . . . 11
- Example OT Architectures . . . 11
- Stakeholders . . . 12

Safety and Security 14
- Availability is Paramount . . . 14
- Safety and Security Culture . . . 15

OT for IT Security People 16
- Understanding the Cultural Divide . . . 16
- The Reality of OT Systems . . . 16
- The Mitigation-First Approach . . . 17
- When Mitigations Fail . . . 18
- The Cascade Effect . . . 19
- Incident Response Challenges . . . 20
- The Path Forward . . . 20

Security for OT: Why Is It Problematic? 22
- The Historical Context . . . 22
- The Turning Point: Stuxnet and Beyond . . . 22
- Current Challenges . . . 23
- Common Problems and False Assumptions About OT Security . . . 23
- Advantages of Security . . . 29

Related Frameworks, Standards, and Regulations 30
Frameworks . . . 30
Standards of Other Organizations . . . 30
Regulations . . . 32
Existing Vulnerabilty Lists . . . 33
Mapping Table . . . 33

III. The Top 10 34

The OWASP Operational Technology Top 10 35
Structure of Each Top 10 Item . . . 35
Methodology . . . 36

1. Unknown Assets and Undocumented Services 37

2. (Accessible) Devices with Known Vulnerabilities/Issues 41

3. Inadequate Supply Chain Management 45

4. Loss of Availability 49

5. Insufficient Access Control 53

6. Missing Incident Detection/Reaction Capabilities 57

7. Broken Zones and Conduits Design 62

8. Missing Awareness 65

9. Selection of Components/Protocols With Insufficient Security Capabilities 69

10. Missing Hardening 72

IV. Where to Start 76

What's next and Where to Start? 77
For existing Systems . . . 77
For new Systems/Components . . . 77
Prepare for Incidents . . . 78
Additional Reading . . . 78

V. About the Project 79

About OWASP 80

Community and Contributing **81**
How to Contribute? . . . 81
Empirical Data Contribution . . . 81
How to Test Your Changes Locally Before Submitting . . . 81

List of Our Contributors **83**

Related OWASP Projects **84**
OWASP IoT Top 10 . . . 84
OWASP Top 10 . . . 84

VI. Appendix **85**

Mapping table **86**
1. Unknown Assets and Unmanaged External Access . . . 86
2. Devices with known Vulnerabilities/Issues . . . 86
3. Inadequate Supplier/Supply Chain Management . . . 86
4. Loss of Availability . . . 87
5. Insufficient Access Control . . . 87
6. Missing Incident Detection/Reaction Capabilities . . . 88
7. Broken Zones and Conduits Design . . . 88
8. Missing Awareness . . . 88
9. Insufficient Security Capabilities . . . 89
10. Missing Hardening . . . 89

Glossary **91**

Part I

Introduction



> **Community and Contributing**
>
> Please don't hesitate to contact the OWASP OT Top 10 project with your questions comments, and ideas, either publicly by adding issues or providing commits on our github page. Please join the OWASP OT Top 10 Slack Channel to chat. You can get a free invitation to the OWASP slack server through this website.
>
> We do a video conference every first monday of a month from 4pm to 5pm CET/CEST using https://meet.google.com/gwi-vhxz-rjr. We also provide an public ics calendar series that you can add to your calendar.
>
> If you want to contribute, please see our contributing guide. Basically, all work happens public on github and through merge-requests. If you plan a larger change, it is always a good idea to talk with us during one of the Monthly meetings first.

OWASP OT Top 10

Operational Technology (OT) encompasses a wide variety of programmable systems and devices that have direct or indirect interactions with the physical environment. These technologies are integral to numerous sectors such as manufacturing, energy, transportation, medical, and utilities, where they play a crucial role in the operation and management of physical processes.

As OT systems become more interconnected and integrated with Information Technology (IT) networks, they face increased vulnerability to large-scale cyber attacks. This integration, while beneficial for operational efficiency and data sharing, exposes OT systems to the same cyber threats that typically target IT environments.

The risks associated with OT are particularly significant because these systems control physical processes. Unlike IT environments, where cyber attacks primarily impact data, breaches in OT systems can lead to catastrophic outcomes, including physical damage, safety hazards, and disruptions to critical infrastructure. Therefore, securing OT systems is paramount to prevent potentially severe consequences. The significance of safeguarding OT environments cannot be overstated. These systems are integral to the functionality of critical infrastructure, and thus society.

Despite their importance, OT systems often lack the robust cybersecurity measures more commonly found in IT environments. This is primarily due to the legacy nature of many industrial control systems (ICS) and the historical prioritization of operational goals. In OT, security principles follow the CIA triad - Confidentiality, Integrity, and Availability - but with a different emphasis than IT. Availability and safety are typically the highest priorities, as downtime or unsafe conditions can lead to severe operational, financial, or even physical consequences. Confidentiality and integrity, while still important, often take a secondary role compared to ensuring continuous and safe operations. This difference in prioritization has shaped the design and security posture of OT systems over time.

Aim & Objective

The goal of the **OWASP Operational Technology (OT) Top 10** is to raise awareness about the top security risks and vulnerabilities specific to Operational Technology (OT) environments. By providing actionable recommendations, we aim to improve the security posture of OT systems and protect critical infrastructure from cyber threats.

Scope

The scope includes all the devices in the OT-domain. This includes devices that are part of the core functionality of the system (CNC machines, SCADA systems, centrifuges, insulin pumps, HVAC,…) as well as all related devices (HMI, barcodescanner, surveillance cameras on the shop floor, virtualization servers and VMs with core functionality,…). Office IT and edge devices that are not directly related to the main OT purpose are not in scope.

Target Audience

This document is intended for professionals involved in the development, integration, and operation of OT systems, including system developers, integrators, and operators. It also provides value to development managers, product owners, QA professionals, program managers, and anyone engaged in building or maintaining software components for OT environments.

While developers can proactively create secure components, integrators are often limited to implementing mitigations. Recognizing this distinction is important for applying the guidance effectively.

The goal is to make these groups aware of the unique security challenges in OT environments and the risks that can (and likely will) arise if security is overlooked. Awareness measures may come from internal policies or supply chain requirements, and this document supports both approaches.

How to Use This Document

The primary purpose of this document is to raise awareness of common security problems in the OT space and provide a foundation for addressing them. It introduces developers and integrators to the OT world and its specific requirements, helping them anticipate vulnerabilities and apply mitigations.

Readers should use this document as:

- **An awareness tool** for understanding critical OT security risks.
- **A reference guide** for best practices and mitigations.
- **A foundation for policy and supply chain requirements**, helping organizations align internal guidelines with external mandates.

- **A starting point, not a complete solution** - while the Top 10 risks are critical, they are not exhaustive. Additional risks may exist, and organizations should build a comprehensive security strategy beyond this list.

The Top 10 List

During the discussions, we agreed upon the items of the top 10 list while the respective ranking was highly subjective. Items 1 to 4 were selected as the Top 4 because there was consensus that these are fundamental for OT security, items 5 to 9 were all deemed to be of similar high importance, and the final item is not a security issue by itself but would have prevented many of the incidents reported from the field.

The Summary gives you all ten items with one sentence each, The Top 10 has the full chapters.

Project Leaders (in Alphabetical Order)

- Andreas Happe
- Felix Eberstaller
- Siegfried Hollerer
- Simon Rommer

Copyright and License

This document is released under the Creative Commons Attribution-ShareAlike 4.0 International license. For any reuse or distribution, you must make it clear to others the license terms of this work.

Summary

OT runs the physical processes we all depend on: power plants, production lines, water treatment, medical devices. They are built for availability and safety, operated for decades, and now connected to office IT, their vendors, and often the internet. When things go wrong in IT, the usual impact is data loss; when things go wrong in OT, production stops, equipment is damaged, and people can be hurt. The ten items below are the risks and missing practices our contributors keep running into, not individual vulnerabilities.

The Top 10 at a Glance

The Top 4, on which there was consensus that they are fundamental:

1. **Unknown Assets and Undocumented Services**: If you cannot see it, you cannot patch, segment, or monitor it; undocumented services and forgotten remote access are how intruders reach the process.
2. **Devices with Known Vulnerabilities**: Exposed devices with known vulnerabilities are easy, high-value OT targets. A single exploited PLC, HMI, or RTU can bypass upstream defenses and threaten the process.
3. **Inadequate Supply Chain Management**: Vendors, integrators, and maintenance providers already have privileged access, so attackers use them to scale one compromise across many operators.
4. **Loss of Availability**: Availability is the primary OT requirement. Outages can result from malware, unsafe changes, integrity failures, or faulty updates.

The next five, all deemed to be of similar high importance:

5. **Insufficient Access Control**: Shared passwords, missing roles, and remote access without MFA turn one stolen credential into a path to the process.
6. **Missing Incident Detection/Reaction Capabilities**: Without logging, monitoring, and tested response, intrusions persist unseen for months and escalate from small incidents to major outages.
7. **Broken Zones and Conduits Design**: Flat networks let one compromised host reach many systems. The right zone design matches how the plant actually communicates and limits the blast radius.
8. **Missing Awareness**: Controls must be understood and supported by operators. When staff do not know why a security measure exists, it is bypassed or disabled to keep production running.
9. **Insufficient Security Capabilities**: OT systems last decades; equipment or protocols selected without authentication, encryption, or update capability create legacy risks that are hard to remediate later.

Not a security issue by itself, but it would have prevented many reported incidents:

10. **Missing Hardening**: Hardening does not eliminate vulnerabilities, but it raises the cost of exploitation. In our experience, lack of hardening is what turned a vulnerability into a breach.



Part II

Operational Technology (OT)

Defining the Domain: CPS, OT, and ICS

When we talk about securing industrial environments, it is important to recognize that not all digital systems are created with the same goals in mind. Traditional IT focuses on data - how it is stored, processed, moved, and protected. Operational environments revolve around the physical processes. To understand this landscape, it helps to imagine three layers, each nested within the other.

Cyber-Physical Systems (CPS) are integrated systems combining computation, networking, and physical processes. This category is expansive and includes everything from an autonomous vehicle navigating traffic to the interconnected sensors and controllers that regulate a smart city.

Within CPS lies **Operational Technology (OT)**, a more specialized domain focused specifically on industrial, utility, and critical infrastructure environments. OT encompasses the machines, control software, and communication networks. These systems are built to keep essential processes running safely, reliably, and often continuously.

Within the OT domain, **Industrial Control Systems (ICS)** represent a major subset comprising technologies. ICS refers to the specific components that carry out control functions on the shop floor or within an industrial process. This includes Programmable Logic Controllers (PLCs) that open and close valves, Supervisory Control and Data Acquisition (SCADA) systems that supervise entire facilities, and Human–Machine Interfaces (HMIs) that operators use to monitor temperatures, pressures, and production flows.

ICS architectures form the backbone of industrial operations and are often used interchangeably with the term OT in cybersecurity contexts.

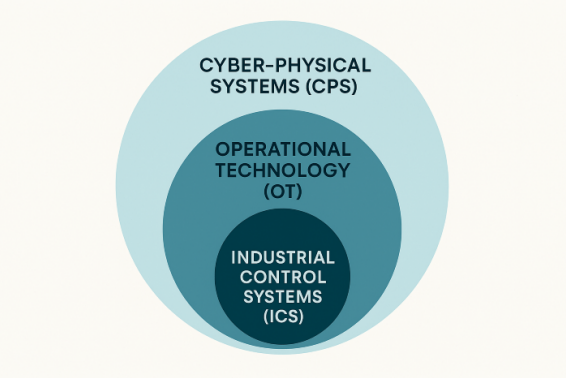


Figure 1: Cyber-physical systems, OT and ICS

Overall, OT systems are essential for the operation of many industries, and they far outnumber Information Technology (IT) systems in use. OT security problems in these industries can have major impacts on the society and surrounding environment.

The Purdue Model: Organizing Systems by Function

The Purdue Reference Model provides a functional hierarchy commonly used to describe and segment OT environments. It separates systems based on their operational role and their proximity to the physical process, enabling clearer security boundaries and communication paths. While initially deployed in the 1990s, the Purdue Model today exists in many slightly modified versions, but in general there are 6 separate levels and additional DMZs between them. The image below shows these levels starting with Level 0 (the actual physical field devices) up to Level 5, where the enterprise IT resides.

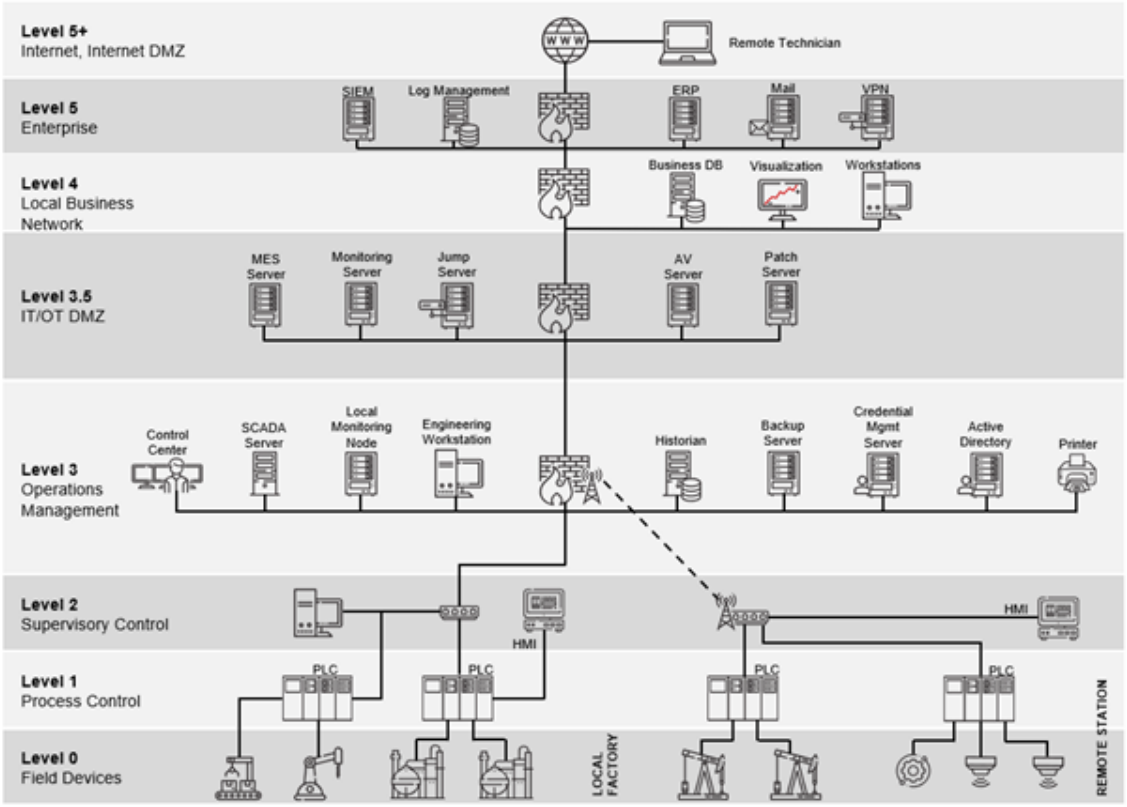


Figure 2: Purdue Model Architecture Example (source: Limes Security)

Levels 0–1: Direct Interaction with the Physical Process

Levels 0 and 1 include systems that interface directly with physical equipment. Interruptions or compromise at this layer have immediate, real-time operational impact.

- **Level 0 – Field Devices.** This level consists of sensors, actuators, valves, motors, and other field devices that monitor or affect physical parameters such as temperature, pressure, flow, or position.
- **Level 1 – Process Control.** This level contains devices that read data from Level 0 and issue control commands. Common technologies include:
  - **Programmable Logic Controllers (PLCs):** Small computers that execute the logic to run a machine.

  - **Remote Terminal Units (RTUs):** Similar to PLCs but typically deployed across long distances or remote infrastructure (e.g., pipelines).
  - **Intelligent Electronic Devices (IEDs):** Specialized control and protection equipment, used primarily in electric power systems.

Levels 2–3: Indirect Interaction and Operational Management

Levels 2 and 3 provide supervisory and operational functions. These systems do not control hardware directly but communicate with Level 1 devices to monitor or adjust the process.

- **Level 2 – Supervisory Control.** Systems at this level provide the interface for humans to interact with the machines.
  - **Human–Machine Interfaces (HMIs):** Localized operator screens for viewing process states and issuing manual commands to specific machines.
  - **Supervisory Control and Data Acquisition (SCADA) Systems:** Aggregated supervisory platforms that collect data from multiple controllers (PLCs/RTUs) to provide centralized visibility across an entire facility or distributed environment.
- **Level 3 – Operations Management.** Systems in this layer manage production workflows and facility operations across the site. Typical examples include:
  - **Manufacturing Execution Systems (MES):** Coordinate production processes, material flows, and operational tracking.
  - **Building Automation Systems (BAS):** Support infrastructure such as Heating, Ventilation, and Air Conditioning (HVAC), lighting, and environmental controls within industrial sites.

While the core of OT sits at **Levels 0–3**, the Purdue Model extends into the corporate world. It is important to note that this is not a strict, universal blueprint, but a reference model to help define trust boundaries.

- **Level 3.5 – IT/OT DMZ (Demilitarized Zone).** This is the most critical security boundary. It acts as a "buffer" between IT and OT. Since most security incidents originate in the IT environment (e.g., phishing), this layer prevents an infection from spreading directly to the controllers at Level 1.
- **Level 4 – Local Business Network.** The local office network at the plant site (e.g., local engineering workstations or site-specific ERP).
- **Level 5 – Enterprise.** The corporate headquarters network, where centralized services like email and global HR systems reside.
- **Level 5+ – Internet & Internet DMZ.** External connections, cloud-based analytics, and remote vendor access.

The IT/OT Convergence: Defining Functional Context

In modern industrial settings, the distinction between IT and OT is not defined by the hardware itself, but by the *function* the device performs and the *context* in which it operates. This is known as IT/OT convergence - where traditional IT components are used to manage physical processes.

To determine if a system belongs in the OT domain, consider the following "litmus test" questions:

1. **Physical Impact:** If the device fails or is compromised, does it directly affect a physical process or life safety?
2. **Environment:** Is the device located on the factory floor or within a secured industrial network (Levels 0–3)?
3. **Primary Goal:** Is the system's most critical requirement Availability (keeping the process running) rather than Confidentiality (protecting data)?

Example: The Video Camera

Consider a standard IP video camera. If that camera is installed in a corporate lobby to monitor for unauthorized visitors, it is a traditional **IT asset**. Failure results in a loss of records but no impact on business operations. However, if that same model of camera is placed on a factory floor to allow an operator to monitor a high-pressure furnace or a robotic assembly cell, it becomes a critical **OT asset**.

Example OT Architectures

A typical OT system consists of control loops, human-machine interfaces (HMI) and remote diagnostics and maintenance tools like depicted in the image below.

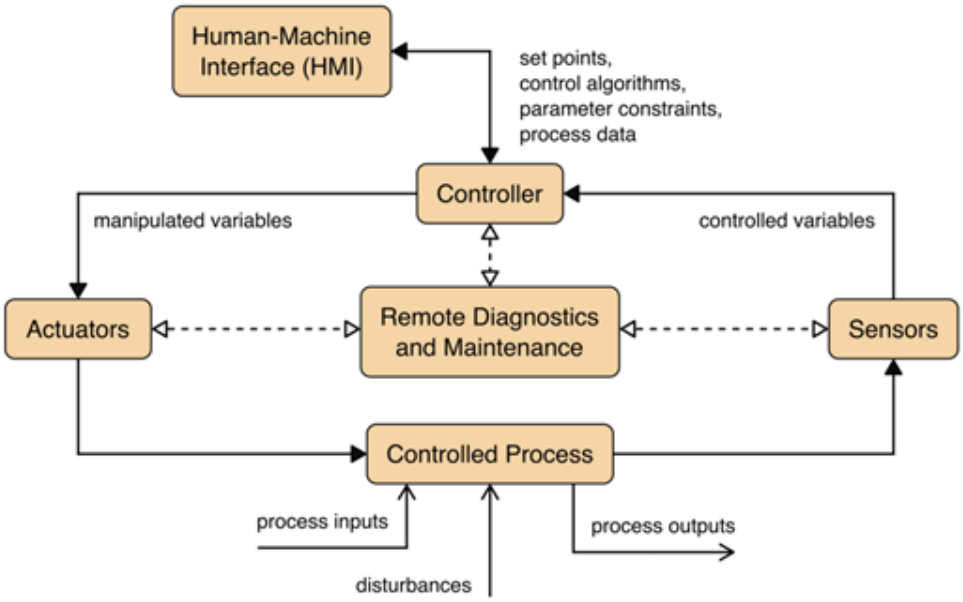


Figure 3: Components of an OT System (source: NIST SP 800-82r3, p. 11)

A control loop is meant – as the name suggests – to control some kind of process. To do so, the loop employs a combination of sensors, actuators and controllers. Sensors measure certain physical properties like temperature or pressure and send these *controlled variables* to the controller. This component acts as the brain of the loop. By interpreting the sent information based on a control algorithm and target set points, so-called *manipulated variables* are created. These are sent to the actuators, which are the components that directly manipulate the controlled process according to the commands of the controller.

For example, a sensor that measures the temperature of a boiler sends the controlled variable *temperature* to the controller. If the controller determines that the measured temperature is below the set target, he instructs an actuator to activate the heater rod of the boiler until the temperature matches the set target temperature again.

This process can mostly be monitored and manipulated by human operators via the so-called HMI. In our example the HMI maybe allows the operators to change the target temperature and to observe the current state of the boiler. Finally, remote diagnostics and maintenance tools can be used in case of abnormal operation of the system or solution.

Stakeholders

Achieving robust security in OT environments requires close collaboration between several key parties. The international standard for OT security, **IEC 62443**, identifies four primary roles, each with distinct responsibilities and security challenges:

- **Asset Owner:** The entity that operates the industrial facility (e.g., a power plant or factory). They are responsible for the overall security of the environment and are usually the ones who implement high-level defenses like network segmentation.

- **Product Supplier:** The company that develops and manufactures the components, such as PLCs, HMIs, or networking hardware. They are responsible for "security-by-design," ensuring the hardware and software are resilient before they reach the customer.
- **Integration Service Provider (Integrator):** The party that assembles individual components into a complete automation solution tailored for a specific site. They ensure that the different parts work together securely within the owner's infrastructure.
- **Maintenance Service Provider:** The entity (often an external vendor) responsible for the ongoing upkeep of the systems. They are a critical security link because they frequently require remote or physical access to the "heart" of the control system.

OT security challenges are different for these stakeholders, which is also reflected in the different standards of the IEC 62443 series. For example, an operator does not have access to the development process of the specific component and thus cannot implement security measures at the source code level.

On the other hand, the operator more or less can shape the intended environment where the solution is employed and therefor is capable of introducing mitigating measures like strong network segmentation.

As the impact of security failures in OT can be tremendous, there is an increasing number of laws and regulations governing the development and operation of OT systems and devices. Examples are the European NIS2 and the Cyber Resilience Act (CRA), the US EO14028 or the China Cybersecurity Law.

Safety and Security

Although there is an increasing convergence of IT and OT and regular IT systems are just as well used in OT environments, there are nonetheless fundamental differences in security goals and security culture. When assessing the security impact of security vulnerabilities, IT security people often refer to the "CIA triad". The acronym is built from the starting letters of Confidenciality, Integrity and Availability.

While in IT commonly confidentiality and integrity are paramount, confidentiality is mostly of lesser importance in OT as it is often employed in more or less physically restricted environments. **The most important goal in OT is safety, as humans can get harmed** or even worse get killed when OT systems and devices malfunction.

This is further complicated by the fact, that e.g. in German Safety and Security are actually the same world ("Sicherheit"), leading to too many "lost-in-translation" effects even while using the same language.

Availability is Paramount

Besides that, availability is paramount. Be it production site, be it critical energy infrastructure – many OT environments cannot afford even the smallest downtime. This also is reflected in security testing of OT, where many tools that are commonly deployed in IT environments can carry a significant risk if not used carefully in OT.

For example, a simple port and service scan with the well-known tool *nmap* is a common approach to start off the enumeration in a penetration test. While this is totally fine in most IT systems, there are many PLCs that can crash if they receive such packets. This is mainly due to their highly specific intended usage in certain processes and the resource constraints that come with them. Additionally, due to special requirements like real-time capabilities many proprietary protocols are used to complement standard protocols. This makes the testing process harder in general as there is less crossover between different environments.

Worst-Case Scenarios

The focus on safety and availability is also reflected in OT worst-case scenarios. While in IT loss of data confidentiality or manipulation of data is often catastrophic, OT worst-cases are loss of view (LOV) and loss of control (LOC). LOV describes a scenario where the operators do not have visibility or correct visibility of what is happening with the process. So the systems still operate, but it is unknown what they are currently doing and if they are actually doing the right thing.

An example for LOV was when Stuxnet manipulated monitoring of Iranian operators to mislead them thinking that everything was working correctly. LOC, as the name implies, means that the operators cannot control the process and its systems anymore more, making them unable to respond to possible unsafe operations.

CIA-Triad in IT and OT

In traditional IT systems, we often emphatise Confidenciality and Integrity. For example, when you look at a web-shop, it is important that no sensitive user data (such as passwords or orders) are exposed (confidenciality) and that invoices cannot be changed by attackers so that they pay less money (integrity). Availability is often only an after-thought: if the shop is down, it's down. The company might not make any money from orders, but they will not be sued due to exposed passwords or loose money through maliciously altered invoices.

The OT world works differently. Here availability is paramount: the worst case if often that, e.g., a power plant is not producing any power anymore (availabiliity) and this is more severe than exposing financial data of the power plant company (confidenciality).

Sometimes, this differentiation is not as clear-cut: imagine an attacker can alter transmitted usage data (integrity) and through that misleads a power plant to over- or under-produce power (availability).

Safety and Security Culture

While security culture is shifting in OT and is undeniably growing in importance due to an increasing number of regulations and cyberattacks, this culture shift unfortunately is quite slow.

Unlike IT systems with their short lifetime, OT systems are used for 15 to 20 years.

As patching is often not possible due to the resource reasons and possible outages mentioned before, there are many vulnerable legacy systems and insecure protocols in active use for years to come. Especially those protocols sometimes have to be completely redesigned, as security was not an issue when they first were conceived. Also the mindset of the engineers and their organizations often times is not the same yet as of IT engineers.

While having a very good understanding of the prevention of accidents and therefore required safety measures, the notion that there are indeed attackers deliberately causing such "accidents" is not as widespread as much as it is needed yet.

Additionally, many companies are not as open to vulnerability disclosures as most IT companies yet. Fortunately, this is also currently changing and more and more OT organizations see the value in transparent and proactive handling of discovered vulnerabilities.

OT for IT Security People

This introduction explains why OT security looks the way it often looks, specifically for IT security professionals who may be encountering operational technology environments for the first time.

Understanding the Cultural Divide

All professional communities have their own work culture and mindset, and people only working in IT security may not even be aware of the cultural "waters" in which they "swim". **OT is a separate culture** and things work rather differently than in traditional IT environments.

When IT security people look at OT scenarios, some misconceptions often occur, sometimes leading to well-intentioned but impractical suggestions like:

> *"Why don't you just update components?"*
>
> *"Why don't you replace these insecure protocols?"*
>
> *"Just buy new hardware!"*

While these solutions work perfectly in IT environments, **the situation and requirements within the OT world are fundamentally different** from typical IT requirements. Understanding those differences helps to understand how many OT security challenges came to be.

The Reality of OT Systems

Some of the fundamental conceptual differences in the OT world include:

Decades, Not Years

- **Long lifetime of products**: decades rather than years of operational life
- **Think about this:** Remember computer security thirty years ago? Limited encryption, basic authentication, minimal network protections? This is our current security level in some OT setups today.

The Update Paradox

- **Hard to Update**: it's rather hard to update a power plant. To do this you might need a spare power plant to bridge the loss of power generated by the currently-being-updated facility

- In other critical domains, such as life-sustaining medical devices, updates might not even be possible without directly endangering users
- **Every downtime must be meticulously planned** in advance, unlike IT systems that can be patched and rebooted quickly

Protocol Limitations by Design

- **Lack of Integrity-Protection or encrypted Protocols**: due to the long lifetimes, many OT protocols neither support encryption nor integrity protection
- Within manufacturing environments, encryption is actually not a desired feature as it makes network monitoring and troubleshooting significantly more complex
- When a production line goes down, operators need immediate visibility into what's happening

These are operational realities within the field with which we have to deal. Very often, we do not work in greenfield projects but have to adapt existing systems while improving security. **The alternative - replacing all legacy OT systems immediately - is neither economically feasible nor operationally safe.**

Additional challenges include vendors not providing security updates for legacy systems and devices lacking proper access control mechanisms by original design.

When you look into recent news, OT security incidents are on the rise. While it would be preferable to have a perfectly secure solution, sadly we're currently only catching up and thus any substantial security improvement is welcome.

The Mitigation-First Approach

As shown above, in the OT world we often have to deal with potentially inherently insecure devices that might not be updated or upgraded. The fundamental approach becomes:

> If we cannot make the devices themselves secure, we try to prevent attackers from accessing them in the first place.

This is typically accomplished through mitigations such as:

Network Separation

- Air-gapped networks where possible
- VLANs and network segmentation
- Strict firewall rules between IT and OT networks

Physical Security Controls

- Locked control rooms and equipment cabinets
- Badge access systems and restricted access to industrial floors
- Being able to 'lock away' devices and their networks helps compensate for protocols without integrity or confidentiality protections

These remediations are not a "get out of jail free" card and impose limitations as well as maintenance burden. Please note that we would prefer to have secure devices (or even zero-trust enabled devices) but until then, often those mitigations are the only way of keeping critical infrastructure operational.

The Risk Calculation Problem

As risk is typically calculated by **"Risk = Likelihood × Impact"** and these mitigations would theoretically reduce the likelihood to zero, we should be able to close the case, right?

Sadly, NO. This is where the fragility of the approach becomes apparent.

When Mitigations Fail

The overall architecture of "protecting insecure devices by preventing attackers from accessing them" has a critical weakness: **it breaks down completely if attackers find a way to bypass these protections.**

What could go wrong with our mitigations? Consider these real-world scenarios:

The Insider Threat

- Your system depends upon no one introducing malware into an internal network, but users attach infected USB sticks
- **Stuxnet case study:** Even air-gapped systems proved vulnerable when the attack vector came from within (stuxnet)

Network Segmentation Failures

- Missing network segmentation between factory floor and office networks leads to numerous incidents
- Many reported "OT incidents" are actually ransomware attacks that originated in attached IT infrastructure and spread due to poor network boundaries

Physical Security Breaches

- Problems with physical security allow unauthorized personnel to access factory floors and directly manipulate control systems
- Unlike IT systems protected by multiple authentication layers, OT devices often assume anyone with physical access is authorized

Management Interface Vulnerabilities

- IT professionals use BMC for out-of-band administration
- Similar remote management capabilities in OT networks can provide attackers with direct pathways from IT to OT networks, bypassing traditional security controls (if similar things are used within OT networks)

The Cascade Effect

If attackers successfully compromise the perimeter, we typically encounter recurring major problems:

Inherent Device Vulnerabilities

- The insecure devices are, by design, easy to exploit
- Communication between devices can be intercepted and altered due to lack of encryption or integrity protection
- Default credentials and weak authentication are common

Large Blast Zones

- Attackers can use compromised devices to further propagate and pivot into other 'secured' networks and devices
- Trust relationships between systems assume all connected devices are legitimate
- Network protocols designed for operational efficiency facilitate rapid compromise propagation

Operational Impact

- Unlike IT systems, OT compromises can affect physical processes
- Safety systems may be targeted or inadvertently affected
- Production downtime has immediate financial and potentially safety implications

Fragility is a major concern, so considering downstream implications when mitigations fail is critical. **Monitoring to detect compromise and defense in depth become essential additional layers.**

Incident Response Challenges

Compared to well-maintained traditional IT systems, **OT systems often display a severe lack of recoverability**. Very often, compromised organizations are not able to effectively react to or recover from incidents.

This limitation stems from several factors:

Backup and Recovery Gaps

- Missing backups/disaster recovery plans for critical control systems
- Missing configuration backups for OT devices, making restoration difficult or impossible
- Undefined processes for alert reporting/handling
- Limited testing of recovery procedures due to operational constraints

The "Reboot" Problem

Traditional IT incident response relies on the ability to "easily" reboot systems, reimage machines, and restore from known-good backups. **This assumption breaks down in OT environments.**

You can reboot your computer or server, but rebooting a whole factory or connected power station requires:

- Coordinated shutdown procedures
- Safety system verification

- Gradual restart processes
- Extensive testing before returning to full operation

Example: A chemical plant cannot simply "restart" after a security incident. Each system must be carefully verified, safety interlocks tested, and processes gradually brought back online to prevent equipment damage or safety hazards.

The Path Forward

We hope this introduction explains why we often have to make compromises to achieve meaningful security improvements in OT environments. In legacy settings, this mostly means depending upon mitigations such as network segmentation and physical access management.

While newer systems will eventually alleviate many of these problems, **we still have to deal with legacy systems to keep existing critical infrastructure running.** The alternative - replacing all legacy OT systems immediately - is neither economically feasible nor operationally safe.

The Double Meaning of Compromise: Compromise has another meaning in this context. Often we over-rely on mitigations and when those are not upheld, our systems become compromised. If there are no additional defense-in-depth measures in place, the potential fallout is immense as further compromisable systems are often within the blast radius. This makes additional hardening even more important than in traditional IT systems.

Key Takeaway for IT Security Professionals: Understanding these unique constraints is the first step toward contributing meaningfully to OT security solutions that work within operational reality rather than against it.

Getting critical infrastructure secure will be quite a journey. But that is no excuse for not starting this journey right now.

The path to OT security requires bridging two worlds - the methodical, safety-focused culture of operations with the adaptive, threat-focused mindset of cybersecurity.

Security for OT: Why Is It Problematic?

While the term “operational technology” (OT) is fairly new, originating in the early 2000s, the underlying technology is not. Ranging back to mechanical control systems, industrial control systems (ICS) for example have come a long way.

PLCs were already introduced in the 1960s, predating the first personal computer (the Apple 1 in 1976) by over a decade. Also, the integration with SCADA, starting in the 1980s, took place at the same time as the Internet was just beginning to become established more broadly. This long-standing history created a very specific culture amongst the engineers and operators designing and using such systems, coming with its own tenets, views and best practices.

The Historical Context

Naturally, at the onset of OT, malicious attackers were not a problem to be thought of – at that time they weren’t even for IT. But even when cyber-attacks finally materialized increasingly, they spared OT by large. The technology was:

- Difficult to understand
- Even more difficult to get access to
- Systems did not feature the kind of connectivity they do today
- The attack surface was far bigger and more rewarding on the IT side

It should come to no surprise therefore that in comparison to **safety** – which was and is paramount in OT – security was never a large concern historically. With operators coming mainly from an engineering background, they also did not pick up the cultural security changes that have manifested in the IT community over the last decades.

The Turning Point: Stuxnet and Beyond

For quite a long time this did not prove to be problematic, attacks almost exclusively targeted IT systems. But then, **in 2010, the discovery of Stuxnet sent shock waves through the security community**, putting ICS and soon OT in general in an ever-increasing focus.

Over half a century after the introduction of the first PLCs, the rate of occurrence of ICS-related attacks and malware started to rise steeply throughout the 2010s with the time between attacks ever decreasing since.

Notable Attacks:

- **Industroyer (2016)**
- **TRITON (2017)**
- **Industroyer2 (2022)**

These are just some of the most infamous attacks, showcasing how security incidents can degrade **safety and availability** – the traditional top concerns in OT.

Current Challenges

While cultural security issues mentioned above still persist (but are decreasing), OT often suffers from additional structural and organizational problems when trying to tackle the growing threat from malicious actors.

Key Issues:

- Many organizations simply **cannot easily update** or substitute vulnerable systems like it is mostly possible in IT
- The adage *"never change a running system"* becomes even more true when dealing with critical infrastructure
- Systems have a **very long lifetime**, exposing them to outdated software and subsequent known vulnerabilities

Example: It is simply not possible to shut down a whole power plant on short notice to install an emergency patch for a newly detected vulnerability.

All these factors and more – growing threat landscape, increasing connectivity in OT for more efficient management and operation, insufficient security – have lead governments and regulatory bodies around the world to introduce legislation effectively forcing the OT community to evolve their security culture and posture like IT has done over the last two decades.

Common Problems and False Assumptions About OT Security

Changing cultures and even more so carefully engineered complex and critical systems like power plants, production sites and traffic control systems has the potential to cause friction and problems. This is totally understandable, as even in IT the introduction of new security technology and measures can create major pain points in the beginning.

> **Important:** Neglecting security for a short-time saving of money and effort is a perfect setup for even more complications in the future when legislation tightens or if an actual attack happens.

Think about it this way: When security measures are planned and introduced, **you dictate the circumstances**, the execution time and potential downtimes. But when you have to respond to a security-related incident the circumstances dictate everything. You then have very limited say in downtimes, required resources and above all the time when it has to happen.

Security vs. Safety

> *"We do not need security, we have more than enough safety mechanisms in place"*

As acknowledged before, **safety is paramount** – and with good reason! An exploding turbine affecting the lives of operators around it is undeniably more serious than a file server in an office getting encrypted by ransomware.

Looking at safety in OT reveals how diligently the OT culture treats risk to life. Most of the time, there are multiple layers of safety mechanisms ensuring that even in face of failure of one layer, another one intervenes.

Defense in Depth This concept, commonly referred to as **"defense in depth"**, is also highly relevant to OT security. But even in face of these intricate safety mechanisms, think about cases where safety systems are explicitly targeted by malicious actors to prevent them from kicking in.

Case Study: Recall the aforementioned TRITON malware that explicitly targeted the safety systems of a petrochemical plant.

Key Insight: Security is an active enabler of safety. If security is compromised, this can pose a direct threat to safety systems and mechanisms. Therefore, safety and security cannot be seen as redundant but are **two sides of the same coin** trying to achieve the same goal – keeping the systems running in a safe state.

Security vs. Availability

> *"We cannot harden/update systems to make them secure as we cannot afford the downtime"*

System availability is only second to safety in most cases, so naturally many systems cannot simply be taken down to introduce updates or change configurations. This is often hard to grasp for

security professionals coming from an IT background. Every downtime has to be meticulously planned in advance.

But this does not mean that downtimes are impossible in general. They do happen! Every component needs maintenance at some point in time and OT staff is usually highly experienced to align such maintenance downtimes with business goals and possibly existing regulatory requirements.

Solution: Security Roadmap These time frames should therefore also be used to introduce security-relevant topics. To do so, a **security roadmap** detailing what measure can be implemented at what maintenance downtime has to be carefully crafted.

As said before, this is your advantage when you tackle security in a pro-active way – **you decide on when something happens!**

Patch Management Challenges Of special concern is patch management, as:

1. Patches are usually released more often than there are maintenance downtimes
2. Older systems often do not receive patches at all

Solutions:

- Establish a process rating the severity of a patch
- Align updates and their urgency with maintenance tasks
- More uncritical patches can be postponed to a later point in time
- For critical emergency patches, make plans in advance (often together with suppliers)
- Use “defense in depth” approach for systems that cannot be patched

---

Trusting the Blast Zones

> *“Our systems are isolated so there is no way to access them anyway. We therefore do not need further measures”*

Physical security and isolation are often a major strength in OT environments, far surpassing typical IT environments in that regard. Nonetheless, **relying on access control alone can be deceptive**.

Surely, most environments won’t face the kind of intricacy and effort of nation-state attacks like Stuxnet (which breached air-gapped systems), but just think about a scenario where an employee plugs in a USB stick that is privately owned. If the stick is infected with malware, your OT environment can be compromised soon – **without any connection to the outside!**

Solution: This is a good case for “defense in depth” again: Physical access control and network segmentation are both important factors in a comprehensive security strategy. Without them,

the strategy can barely be called comprehensive, but on their own they also are not sufficient for modern threat landscapes.

Security vs. Performance

> *"We cannot afford to have any delays in network/system/etc. performance caused by security technology"*

This can indeed be a major problem. Especially OT protocols often cater to very specific performance requirements like **real-time communication**. As most of these protocols are quite old, security was not taken into account during creation.

Current State:

- Some newer protocols with security features (like **OPC UA**)
- Some older ones offer security extensions (like **PROFINET**)
- Often not supported by vendors or not applicable to certain tasks

Alternative Approaches: If the protocol layer cannot be secured, then other mitigations like:

- Careful network segmentation
- Monitoring systems

can significantly improve security posture. Especially as the OT security market is ever growing, more and more vendors are coming up with specific OT security products taking into account the complex requirements of many OT environments.

Experience Note: During the years-long experience of the authors of this document, there was never the case that there were no possible security improvements for the environment. Security is not a "one size fits all" product but has to be **tailored to every system and environment**, to find the best possible balance between security and performance/availability.

Knowledge Gaps

> *"We are engineers, we do not have knowledge about security"*

This is also described in the beginning above. OT staff has in general a completely different background and view on security/safety than IT staff. While this at first seems to be a hindrance, **it does not have to be that way**.

The Value of OT Knowledge In-depth OT-specific knowledge is crucial in:

- Securing OT environments
- Detecting and responding to security incidents
- Crafting tailored security strategies

Typically, the engineers working with the systems are the first to notice strange behavior, being the **primary source of (human) detection** of attacks. They also know the specific characteristics, the requirements and the processes coming with their systems.

Bridging the Gap The lack of security know-how can be tackled in several ways:

Option 1: Collaboration Approach If there already is security personnel and no specific OT security team is planned, a closer collaboration between IT and OT staff can lead to greater understanding on both sides.

- IT security staff can come up with viable solutions for OT security problems once they grasp the difference between IT and OT
- OT staff do not have to become in-depth security experts
- Enable OT personnel to think like an attacker and see potential vulnerabilities beforehand
- OT personnel already work with (safety) risks every day, so the required mental effort is often not that high

Option 2: Training and Education There is a steady increase in educational material for OT security:

- Free documents on the Internet
- Instructor-led training programs
- Specific OT security teams (requires time and money investment)

Important: Giving additional security tasks to an already overworked staff is a recipe for disaster. Management must ensure that there are enough resources for those responsible. **Security is not something that can be done besides!**

Security by Obscurity

> *"We are a small power plant/production site/or similar. Nobody will make the effort to attack us"*

This is a sentiment that is often also shared by IT. **Plain and simple, this is a dangerous fallacy** that does not resemble ongoing threats.

Current Threat Landscape:

- While sophisticated nation-state attacks affect only a very small subset of all OT environments
- Threat reports show awareness of malicious actors (criminal, hacktivists) for OT is on the rise
- Rudimentary malware can lead to disruption and availability issues
- **Rise of OT ransomware** - a type of malware that has been haunting IT for years

Opportunistic Attacks In general, more and more OT incidents do not happen because of a specific interest in the target, but due to:

- **Opportunism**
- Chance to extort money
- Amplify a certain political message

by attacking a coincidentally vulnerable OT environment (e.g., newly vulnerable remote access solutions that have to be reachable over the Internet).

Problems with the Supply Chain

> *"Even if we want to integrate security more, many of our suppliers do not feature security in their products"*

Yes, this can be a problem. While regulations force more and more vendors to consider security in their new products, this does not help with already existing systems.

However: Security can be done in many ways and as described before, there are security workarounds for almost all problems. **"Defense in depth" is again the keyword** to look for.

Example Approach: If there is no security control for one specific component (e.g., a PLC), then the additional layers of a DiD approach can provide security by:

- Monitoring the network of the PLCs
- Restricting access to this network segment
- Providing strict access control for engineering via dedicated and isolated workstations
- And so on…

Advantages of Security

All in all, when security is done the right way, it should never be a hindrance, but **an enabler to a resilient, available and safe OT environment**.

While a meticulously tailored security strategy ensures compliance with existing and upcoming legislation and regulations, truly living the strategy brings many operational advantages:

Key Benefits:

Higher confidence in safety of systems as deliberate attacks against safety systems is made more difficult

More resilient infrastructure leading to less downtime of systems in case of an incident

Greater insight in existing assets as a result of needed analyses of status quo

Easier manageability of networks due to appropriate segmentation

More insight into network traffic due to increased monitoring – not only security-related incidents can be detected and handled faster

---

Security and safety working together for a more resilient operational technology environment.

Related Frameworks, Standards, and Regulations

While this document explores the unique challenges in OT networks and systems, there are established standards both from OWASP and other organizations that can provide useful information for suppliers, integrators and operators alike.

Additionally, like mentioned in the introduction, there is also a number of frameworks, laws, and regulations.

Frameworks

MITRE ATT&CK Framework

The MITRE ATT&CK framework is a comprehensive knowledge base of cyber adversary tactics, techniques and procedures (TTPs). It is widely used in cybersecurity to help understand, detect and respond to cyber attacks. The MITRE ATT&CK framework is a living framework that is regularly updated based on real-world observations of attacker behaviour. It provides a structured way to describe how attackers operate, with a focus on how they compromise systems and move through a network.

Standards of Other Organizations

IEC 62443

IEC 62443 is *the* series of standards for OT environments. The series aims to develop cybersecurity robustness and resilience in the industrial control systems and their environments. It offers several standards for operators, integrators and suppliers, for example:

Operators:

- IEC 62443-2-1 *Security program requirements for IACS asset owners*
- IEC 62443-2-4 *Requirements for IACS service providers*

Integrators:

- IEC 62443-2-4 *Requirements for IACS service providers*
- IEC 62443-3-2 *Security risk assessment and system design*
- IEC 62443-3-3 *System security requirements and security levels*

Suppliers:

- IEC 62443-4-1 *Secure product development lifecycle requirements*
- IEC 62443-4-2 *Technical security requirements for IACS components*

NIST SP 800-82r3

NIST's Special Publication 800-82 Revision 3 "Guide To Operational Technology (OT) Security" offers comprehensive guidelines on how to securely deploy and operate OT systems and devices. The document provides an overview of OT and typical architectures and system topologies, looks and common OT threats and vulnerabilities and also gives recommendations on mitigations for identified risks. Due to this, the publication is especially relevant for operators and integrators.

NIST Cybersecurity Framework (NIST CSF)

NIST CSF is a framework introduced by NIST to standardize the approach to managing cyber risk across sectors. In 2024 the second version was released. CSF is applicable to IT as well as OT and therefore is a helpful resource for all operators.

ISO/IEC 27000

The ISO/IEC 27000 standard series – best known for the 27001 standard – defines requirements to establish an information security management system (ISMS). While ISO/IEC 27001 includes those definitions and controls in its annex, ISO/IEC 27002 provides proven guidelines on how to implement those controls. Widely established in IT environments, ISO/IEC 27000 series nonetheless can be valuable for operators and integrators, as many of the processes and the security management from IT can also be adopted to OT. This becomes even more true, when IT and OT security are integrated in a holistic approach to security throughout the whole organization.

NERC CIP

NERC CIP, short for *North American Electric Reliability Corporation Critical Infrastructure Protection*, is a series of standards regulating the cybersecurity of bulk electric system (BES) in North America. Compliance is mandatory for BES operators in the continental United States; the Canadian provinces of Alberta, British Columbia, Manitoba, New Brunswick, Nova Scotia, Ontario, Quebec, and Saskatchewan; and the Mexican state of Baja California Norte.

TISAX

Trusted Information Security Assessment Exchange (TISAX) is another standard for information security management systems. Originally based on ISO/IEC 27001 and adopted for the automotive industry, TISAX nowadays is quite different to ISO/IEC 27001. In 2024, version 6.0 was released. TISAX is only applicable to stakeholders active in the automotive sector.

IEC 62351

IEC 62351 is developed by IEC TC 57 (Technical committee) and is a series of standards for the security of power system control centers and communication networks. Especially relevant for suppliers and integrators in the energy sector.

Regulations

EU NIS 2 Directive

NIS 2, superseding NIS 1, is a EU-wide legislation aiming at improving the overall level of cybersecurity in the European Union. Published in 2022, all EU member states must adopt the directive through national law starting with 17 October 2024. All enterprises and organizations in scope of NIS 2 are required to fulfill technical and organizational security measure (details have to be defined by the member states) and are subjected to strict mandatory reporting in case of incidents with significant impact. All medium and large-sized companies meeting a certain threshold in 18 critical sectors are included in the scope of NIS 2. It is therefore a highly relevant legislation for operators.

European Cyber Resilience Act (CRA)

The CRA is an upcoming legislation (as of 2024), which intended goal is to strengthen the development of secure products that are placed on the EU market. In scope are all products with digital elements whose intended, or reasonably foreseeable use includes a direct or indirect logical or physical data connection to a device or network. The CRA defines essential requirements for secure design, development and production, requirements on the vulnerability handling processes put in place by manufacturers, rules for the placing on the market of affected products and rules on market surveillance and enforcement of all mentioned requirements. CRA applies to whoever brings an affected product into the EU market.

EU Machinery Regulation

The new EU Machinery Regulation will come into force on 14 January 2027 and will replace the currently existing Machinery Directive 2006/42/EC. The regulation sets requirements for the safe manufacture, commissioning, operation and maintenance of machines and associated products, where safety and security are both stressed. It will affect operators, integrators, suppliers as well as importers and distributors.

EU Radio Equipment Directive

The Radio Equipment Directive (RED) regulates the placing of radio equipment on the EU market for manufacturers and importers. Additional to existing requirements concerning safety,

radio performance and electromagnetic compatibility, an extending requirement aiming to improve cybersecurity, privacy and data protection of radio equipment will come into force on 1 August 2025.

Existing Vulnerabilty Lists

Issuer	Title	Description
BSI	ICS Security Top 9 threats and countermeasures 2022	Focus on impact and vectors (malware, phishing, DDoS, sabotage)
CISA	Top Ten Cybersecurity Misconfigurations	
ENISA	Power Sector Dependency on Time Service	rather specific
ENISA	Transport Threat Landscape	
ENISA	Cyber security and resilience for Smart Hospitals	
ENISA	ENISA Threat Landscape 2023	Figure 8 (Page 16), gives a per-sector attack overview

Mapping Table

A Mapping table linking the OWASP OT Top 10 items to some of the mentioned relevant standard and regulation requirements is provided.

Part III

The Top 10



The OWASP Operational Technology Top 10

During the discussions, we agreed upon the items of the top 10 list while the respective ranking was highly subjective. We selected the Top 4 items as there was consensus that these are fundamental for OT security:

1. Unknown Assets and Unmanaged External Access
2. Devices with known Vulnerabilities/Issues
3. Inadequate Supplier/Supply Chain Management
4. Loss of Availability

The next five items were all deemed to be of similar high importance:

5. Insufficient Access Control
6. Missing Incident Detection/Reaction Capabilities
7. Broken Zones and Conduits Design
8. Missing Awareness
9. Components/Protocols with Insufficient Security Capabilities

The final item is not a security issue by itself but would have prevented many of the incidents reported from the field. We thus included it as final item in the Top 10 list:

10. Missing Hardening

Structure of Each Top 10 Item

Each entry in the OWASP OT Top 10 will be accompanied by a short description, public incidents exploiting that entry, recommended mitigation and countermeasures, as well as references and tooling to assist in addressing the identified risks.

Field	Description
Name	Name/Title of the Item
Description	Show description of the item
Rationale	Why did we find this item important enough for inclusion?
Known Attacks/Examples	What are documented attacks that utilized the respective Top 10 item?

Field	Description
Mitigation/Countermeasures	There will be multiple levels: 1) design and implementation level mitigations for developers/builders; 2) operational mitigations for integrators, e.g., air-gapping systems
Next Actionable Steps	What can be done to identify and/or mitigate the issue?
References	Relevant standards, Links to Tools, and Background Information

Methodology

The project started Autumn 2024 with a meeting of the OWASP OT Top 10 leaders and subsequent announcements to the community. During monthly meetings we discussed potential Top 10 items and their relevance. Starting with 2025, we increased the frequency to one meeting every two weeks to finalize the alpha version.

In addition to the expert opinions, we also gathered empirical data from both offensive and defensive companies and experts. This data was used to validate the proposed top 10 list and ensure that it accurately reflects the current state of OT security.

1 Unknown Assets and Undocumented Services

Arguably the biggest threat to a network (IT and OT) is unmanaged and unknown assets. This can either be unknown assets that are plugged into your local OT network, or undocumented services (in the worst-case available from the public internet and without sufficient access control.

There is an overlap with the Missing Incident Detection/Reaction Capabilities as incident detection depends upon having a complete inventory of the environment. If we do not know what is in our environment, we cannot detect if something is happening to it.

1.1. Description

Unknown assets are devices or systems in an OT environment that are not properly identified or documented. These assets can include legacy systems, unmanaged devices, or unauthorized connections that are not accounted for in the organization's inventory.

This is your typical "shadow IT" problem, but in the OT world, it can be even more dangerous. Unknown assets can be anything from a rogue device connected to the network to an undocumented service running on a server. These assets can introduce vulnerabilities and weaknesses into the system, making it easier for attackers to gain access and move laterally within the network.

These assets are mostly already or will become outdated over time and introduce vulnerabilities and weaknesses into the system. Such assets can for example be used as initial access points into the network, for privilege escalation, establishing persistence or lateral movement. Having a full inventory of assets that not only includes devices but also established remote access, deployed privileges and other services is crucial to understanding the environment we are working with.

Undocumented services can be any service that is not properly documented or managed, such as remote access solutions, cloud services, or third-party applications. These services can introduce vulnerabilities and weaknesses into the system, making it easier for attackers to gain access and move laterally within the network.

A special case of undocumented services are unmanaged external maintenance accounts. They are often used for increased convienience but offer adversaries ample attack opportunities. This can be seen as a case of missing awareness.

Unmanaged External Access

Unmanaged external access refers to connections to the OT environment that are not properly controlled or monitored. This can include remote access solutions, such as TeamViewer

or VPNs, that are not documented or managed by the organization. These unmanaged connections can provide attackers with a way to bypass security controls and gain unauthorized access to the OT environment.

Unmanaged Access for Maintenance

Unmanaged access for external personnel refers to situations where third-party vendors, contractors, or maintenance personnel have access to from within the OT environment without proper oversight or documentation. This can lead to unauthorized changes, vulnerabilities, and potential security breaches.

An example would be third-party contractor (that is connected to the internal network through VPN) that has access to the OT environment for maintenance purposes but does not follow proper security protocols or does not have their access documented. This can lead to unauthorized changes, vulnerabilities, and potential security breaches.

1.2. Rationale

History has shown that undocumented assets can be used by attackers for everything from initial access, via priviledge escalation up to completing the action on objectives. Hardening and segmentation measures can only be complete if all the assets are known and under consideration. Getting an overview of my network is always and therefore the most crucial step when starting with a security program. It is also the fundamental prerequisite for every ISMS, CSMS, and other frameworks.

1.3. Known Attacks/Examples

- Stuxnet
- Triton
- WannaCry
- Colonial Pipeline Hack: The attackers gained access to the system by means of a compromised password for a disused VPN account.
- Someone tried to poison a Florida city by hijacking its water treatment plant via TeamViewer, says sheriff
- CISA and the Environmental Protection Agency (EPA) warned water facilities today to secure Internet-exposed Human Machine Interfaces (HMIs) from cyberattacks.

1.4. Mitigation/Countermeasures

Design and Implementation

- OT-environemts are static by design. During the building phase, the designer or integrator normally provides a detailed description of the environment. Changes to the environ-

ment must be documented. It is crucial to have the documentation process as part of the change process or change management policy.
- If one starts with an already existing environment, the first step to a complete asset inventory can be to take a pen and a piece of paper, go through the location and write down every device that can be seen. This is not only restricted to manufacturing or powerplants, but all types of environments we are working in.

Operational

- mitigations for integrators/builders: Provide the documentation to the customer/asset owner.
- Implement asset discovery and inventory management tools to identify and document all assets in the OT environment.
- Regularly scan and monitor the network for new or unknown devices.
- Perform port/traffic monitoring.
- Enforce strict access controls and authentication mechanisms to prevent unauthorized devices from connecting to the network. Also assume rogue devices/services in the network when designing security measures.

1.5. Next Actionable Steps

- Conduct a thorough inventory of all devices and systems in the OT environment.
- Implement network scanning and discovery tools to identify unknown assets.
- Establish a process for documenting and managing changes to the OT environment.
- Regularly review and update the asset inventory to ensure accuracy and completeness.

1.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.
- Following additional standards are relevant:
  - NERC CIP ID.AM Asset Management
  - NERC CIP PR.AC Identity Management and Access Control
  - NIST 1800-23 Energy Sector Asset Management: For Electric Utilities, Oil & Gas Industry
  - NIST 1800-5 IT Asset Management

Tooling

- ***Network Scanning and Discovery Tools:***: Nmap is the standard OSS active network scanning tool. Be aware that it can be intrusive and may disrupt operations in a production environment. Shodan is a web-based search engine that can help identify devices connected to the internet, including those in OT environments.
- ***Network Monitoring Tools:***: Wireshark is an OSS network protocol analyzer that can capture and analyze network traffic, helping to identify unknown devices and services.

2 (Accessible) Devices with Known Vulnerabilities/Issues

Attackers love to find software/hardware with known vulnerabilities, especially if exploits are already available. Given a sufficiently devastating vulnerability, all other defenses are naught and the attacker can take over the device.

This can be used for initial access, e.g., when exploiting public facing services such as VPNs, or can be used within the target network for Lateral-Movement or Privilege-Escalation.

2.1. Description

If an attacker is able to access a system with known exploitable vulnerable components, most other defense mechanisms are useless. The attacker will be able to take over the system, the only defenses that remain are those that reduce the pwned device's blast radius, i.e., reduces the systems that an attacker can attack "out-going" from the compromised device.

In traditional IT, the typical recommendation is to upgrade. This does not work in OT due to safety concerns, mandatory update time-windows, and generally longer lifetimes of used components. Compared to IT, OT works at a glacial pace.

As updates are sometimes not possible, mitigations such as network segregation are used. This prevents vulnerable systems to become accessible to attackers. Alas, these counter-measures do not solve the problem: if there is a vulnerability within the counter-measure, the original vulnerability can still be exploited. This often makes OT systems very vulnerable against unexpected admin access or badly designed zones: once the attacker is in the network, they have access to exploitable systems and can commence from there.

Why Can't We Just Upgrade All the Systems?

To reiterate on the special problems that the OT world faces, we want to give a list of common excuses/reason given that could prevent an easy implementation of a vulnerability management system:

You don't just upgrade a medical device or power plant: this is not your typical desktop PC where you are annoyed if an update breaks your system for a couple of days, this is critical infrastructure upon which lifes potentially depend upon. Imagine you are depending upon a digital pace maker or insulin pump: would you just update it (without making sure that it will not negativly impact you)?

Problems with the supply chain: compared to traditional IT, in the OT world we have fewer vendors. This gives vendors power over customers, which can lead to a lack of motivation to provide security updates or notify if security problems were discovered.

Usage of legacy devices: due to the long lifetimes of OT systems, many devices are still in use that were designed without security in mind. This can lead to a situation where the device is not able to be updated or patched, even if a vulnerability is discovered. This is especially true for legacy systems, where the vendor may no longer be in business or may not have the resources to provide updates.

Missing Security Awareness on the OT side: while safety is a well understood and implement concept in OT, security is often not. This can lead to a situation where the operators do not understand the importance of security updates and do not prioritize them. This can be due to a lack of knowledge or understanding of the risks involved, or it can be due to a lack of resources or time to implement them.

Unknown devices and shadow infrastructure: if you don't even know about a device, how should you know that you need to update it?

Please note, that this shows (primarily to IT security people) why upgrading is not as simple as in other domains but **does not mean that we (as OT) can use any of this as an excuse for not having update procedures in place**.

Vulnerability Mangement?

Insufficient or missing vulnerability management practices in an OT environment can leave systems exposed to known security vulnerabilities. Not installing security patches eventually, will lead to an amplification effect when (not if) the attacker is within the system.

Even if all the issues mentioned in the last section do not apply for an OT system, security updates are very often not applied. The reason for that is **missing vulnerability management**.

2.2. Rationale

Vulnerable devices bad. Especially in critical infrastructure.

2.3. Known Attacks/Examples

- APT44 is a persistent and operationally mature adversary that uses diverse initial access methods ranging from common vectors such as phishing, credential harvesting, and known vulnerability exploitation to targeted supply chain compromises.
- Volt Typhoon typically gains initial access to the IT network by exploiting known or zero-day vulnerabilities in public-facing network appliances
- Sensitive nuclear information (SNI), the industry's special classification system, was left vulnerable in part because of the use of "obsolete" technology including Windows 7 and Windows 2008, Lawrence said.

2.4. Mitigation/Countermeasures

Design and Implementation

- Try to prevent vulnerabilitites from accessing the system (OWASP SAMM2)
- Test hardware/software before deploying them in the field (OWASP IoT Security Testing Guide, OWASP Firmware Security Testing Methodology)
- Inform customers about security updates. Provide SBOMs.
- Don't depend upon security-by-obscurity.
- Use memory-safe programming languages and utilize security-features of frameworks.

Operational

- Make mandatory vulnerabilty notifications and remediation part of your supplier contracts.
- Keep an up-to-date asset register with hardware/software versions.
- Test hardware/software before deploying them in the field (OWASP IoT Security Testing Guide, OWASP Firmware Security Testing Methodology)
- Establish a vulnerability management program that includes regular vulnerability scanning, patch management, and remediation processes: Prioritize critical security updates and patches for OT systems to address high-risk vulnerabilities.
- Implement network segmentation and access controls to limit the impact of security vulnerabilities.

2.5. Next Actionable Steps

- Inventarize your devices and services
- gather SBOMs and check for known vulnerabilities
- test your devices and services for known vulnerabilities if possible (pen-testing)
- create a risk-based treatment plan, start with mitigations that have the highest impact
- rinse and repeat

2.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.

Background information

- ***OWASP*** maintains the OWASP IoT Security Testing Guide as well as the OWASP Firmware Security Testing Methodology, both of which provide guidance on how to test for vulnerabilities in IoT and firmware systems.
- Software Bill of Materials (SBOM) - CISA describes a component's dependencies and vulnerabilities in a machine-readable format. This can be used to track known vulnerabilities in your software supply chain.

Tooling

- shodan.io allows you to search for devices connected to the internet, including those with known vulnerabilities.
- OWASP dependency-check allows you to scan you Java projects for known vulnerabilities in dependencies. It is typically called manually during software development, but can also be integrated into CI/CD pipelines. OWASP dependency-track accepts SBOMs and can be used to periodically track known vulnerabilities in your software supply chain. It can notify you when new vulnerabilities are discovered.

3 Inadequate Supply Chain Management

Supply Chain Compromise occur when adversaries target weaknesses in an organisation's supply chain - whether it's hardware, software or services provided by third parties. Instead of compromising the target directly, attackers exploit the relationship of trust between the organisation and its vendors or contractors to gain access to sensitive OT systems.

In the context of OT, the supply chain may involve complex vendor ecosystems, including software providers for SCADA systems, hardware manufacturers for industrial equipment, or maintenance services. An attacker infiltrates these supply chain links to gain access to operational technology, bypassing traditional cybersecurity defences.

3.1. Description

It is vital to protect OT supply chains, given their critical role in enabling modern society to function and generate economic prosperity. These supply chains facilitate the production, distribution, and maintenance of essential OT products, systems, and services that underpin various sectors, including healthcare, finance, transportation, and national security. The following phases of the lifecycle of OT components or systems have to be considered when dealing with OT supply chains:

- Design (e.g., requirements specification and architecture)
- Development and production (e.g., raw material procurement and testing/quality assurance)
- Distribution (e.g., logistics and transportation)
- Acquisition, (e.g., retail and sales)
- Deployment (e.g., installation and configuration)
- Maintenance (e.g., use and support, especially provisioning of updates)
- Disposal/decommissioning

3.2. Rationale

Dragos concluded in their global oil and gas cyber threat perspective in August 2019 that the growing threat of supply chain attacks and vendor compromises allows new avenues for activity groups to compromise IT and OT environments alike.

Furthermore, examples like SolarWinds Orion and Crowdstrike threat detection software demonstrated the scalability of supply chain issues, affecting numerous victims at the same time by the very same issue.

3.3. Known Attacks

- SolarWinds Orion Compromise. The SolarWinds compromise was a sophisticated supply chain cyber operation that was discovered in December 2020. The cyber operation involved the injection of malicious code into the SolarWinds Orion software build process, which was then distributed through a standard software update. The cyber actors also used password spraying, token theft, API abuse, spear phishing and other supply chain attacks to compromise user accounts and leverage their associated access.
- CrowdStrike Compromise. In 2024, a content update for CrowdStrike's Falcon sensor software caused global system disruptions. The "Blue Screen of Death" (BSOD) was triggered by a "Named Pipes" update intended to improve threat detection. An error in the update file's formatting led to the CrowdStrike driver accessing a non-existent memory address, triggering the BSOD. This affected numerous industries, including airlines, which canceled or delayed flights; healthcare, which experienced issues with medical records; and emergency 911 call centers, of which up to 100 in the US reported downtime. The outage disrupted businesses relying on OT and conventional IT, highlighting the widespread dependency on reliable technological services.
- Dragonfly. A cyber espionage campaign against a range of targets, primarily in the energy sector, provided the attackers with the capability to carry out sabotage operations against their victims. The attackers were able to infiltrate a number of strategically significant organisations for the purpose of espionage. Had they chosen to utilise the sabotage capabilities at their disposal, they could have potentially caused damage or disruption to the energy supply in the affected countries.
- NotPetya. It was believed that the software update mechanism of M.E.Doc—a Ukrainian tax preparation program that, according to F-Secure analyst Mikko Hyppönen, "appears to be de facto" among companies doing business in the country—had been compromised to spread the malware. Analysis by ESET found that a backdoor had been present in the update system for at least six weeks prior to the attack, describing it as a "thoroughly well-planned and well-executed operation". The developers of M.E.Doc denied that they were entirely responsible for the cyberattack, stating that they too were victims.
- Denmark's Train Network Frozen Due to Cyberattack on Subcontractor.

3.4. Mitigation/Countermeasures

Establish a Supply Chain Management that includes policies and procedures to ensure all devices and components come from trusted suppliers and are tested to confirm their integrity.

Design and Implementation

- It is vital that manufacturers of connectable software and hardware products ensure that such products are developed in line with security-by-default and security-by-design principles, and that their security is maintained during a support period.

- Products should undergo a third-party conformity assessment before they can be placed on the market.
- Consider implementing a multi-vendor strategy.

Operational

- A dedicated notification procedure should be established in the event of a severe incident or an actively exploited vulnerability in a product that may affect multiple parties.
- It is imperative to undertake a thorough evaluation of the risk profile exhibited by suppliers on a regularly basis. This evaluation should be used to determine the necessity of reducing the risk posed by suppliers deemed to be high-risk. If the circumstances necessitate, it is also crucial to impose restrictions on or to exclude suppliers considered to be high-risk.
- Promotion of information exchange, awareness and training addressing supply chain risks.
- Include supply chain attacks in the regular incident, emergency, and crisis management plans and exercises.

3.5. Next Actionable Steps

- Check on a regular basis that critical suppliers have appropriate and proportionate cyber security risk management measures in place to manage identified supply chain security risks. This may be conducted by supplier assessments or requiring relevant certifications (e.g., IEC 62443-4-1, IEC 62443-4-2).
- Ensure that relevant entities are resilient to supply chain threats by conducting preparedness or stress tests.
- Create test platforms or sandbox environments for secure testing.

3.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.

Background information

- ***Noteable CWSs***: the following Common Weakness Enumeration idenifier are highly relevant to this Top 10 item:
  - CWE-912: Hidden Functionality describes an asset that includes functionality which is undocumented, not specified, and not accessible through any interface or command sequence that is apparent to the asset's users or administrators.

- CWE-1361: ICS Supply Chain is a weakness category describes ICS supply chain risks in general. Weakness in this category address for instance the IT/OT Convergence/Expansion, Common Mode Frailties, Poorly Documented or Undocumented Features, and OT Coutnerfeit and Malicious Corruption.

4 Loss of Availability

Availability, esp. in the context of Safety, is paramount and well-understood in the OT world. However, some aspects of availability are still problematic, e.g., integrity is part of availability.

Please note that we talk about protecting “our” infrastructure from DDoS and do not talk about becoming part of a botnet after a compromise (which is also problematic, but rather a subpart of Missing Incident Detection/Reaction Capabilities)

4.1. Description

Availability is the property of being accessible and usable upon demand by an authorized entity. In the context of OT, availability is crucial as many systems are designed to operate continuously and cannot be easily patched or updated without causing downtime.

In the OT domain, availability is often regarded as the most critical security property due to its direct impact on system functionality and safety. If a system is not available, it cannot perform its intended function, which can lead to safety hazards and other issues. Additionally, there is anecdotal evidence of OT components crashing during network scans, underscoring the importance of maintaining availability.

Denial-of-Service Attacks

Denial-of-Service (DoS) attacks are a common threat to availability. These attacks can take many forms, including network flooding, resource exhaustion, and application-layer attacks.

In the context of OT, DoS attacks can disrupt critical systems and services, leading to significant downtime and potential safety hazards. It is important to note that we care about the protection of the OT system itself: if a connected cloud-managed system becomes target of a DoS attack and becomes not available while the OT system/process is still available, this is not an OT availability problem for us.

Real-Time Communication Safety

One special aspect of availability in OT is the need for real-time communication safety. Many OT systems rely on real-time communication protocols to ensure that data is transmitted and processed in a timely manner, e.g., for controlling medical devices or factory automations. If these protocols are disrupted, it can lead to delays or failures in critical processes.

Typical IT network protocols such as TCP/IP are not designed for real-time communication and can introduce latency and jitter that can disrupt the operation of OT systems. Therefore, specialized protocols and hardware are often needed to ensure real-time communication safety

in OT environments. Thus, real-time communication safety is a crucial aspect of availability in OT.

Availability and Integrity

The well known CIA triad (Confidentiality, Integrity, Availability) is often misinterpreted in the context of OT. While integrity is often seen as a separate property, it is actually a crucial aspect of availability.

Imagine a sensor network that is used to monitor the temperature of a critical process. A direct attack against availability would be the destruction of the connected sensors. But if an attacker would perform an Integrity attack, e.g., floods the sensor network with fake temperature data, then the sensor network itself is still available but its sole goal (providing a correct temperature reading) is compromised and thus destroys the availabilty of the overall system.

To protect against integrity attacks, typically cryptographic measures such as signatures or MACs are used. However, these measures can introduce performance overhead and may not be suitable for all OT systems. For example, some legacy systems may not have the processing power or memory to support cryptographic algorithms.

Availability and Software Updates

In the context of OT, software updates are often seen as a risk to availability. This is because many OT systems are designed to operate continuously and cannot be easily patched or updated without causing downtime. However, software updates are also crucial for maintaining the security and integrity of OT systems.

The 2024 CrowdStrike incident is a recent example of how software updates can impact availability. In this case, automatic EDR updates causing significant disruption in multiple OT-areas, e.g., gas stations and hospitals.

4.2. Rationale

- availability is paramount for the safety of OT systems
- the impact of integrity on availability is often overlooked
- recent incidents such as the CrowdStrike incident show that even non-malicious software updates can have a significant impact on availability

4.3. Known Attacks/Examples

- On Feb. 24, 2022, the night before the Russian government launched its full-scale invasion, Russian-backed hackers targeted thousands of modems linked to Viasat, the U.S.-based satellite and internet communications company, and relied on by the Ukrainian military. The attack — attributed to the Russian government by the United

States and its allies — relied on a piece of malware that researchers with SentinelLabs dubbed “AcidRain.”
- Stuxnet: both as an attack against availability and as an example of violating integrity with fake data.

4.4. Mitigation/Countermeasures

Design and Implementation

- perform a risk assessment to identify potential availability threats and vulnerabilities in OT systems
- implement redundancy and failover mechanisms to ensure continuous operation in case of a failure or attack
- use specialized real-time communication protocols and hardware to ensure real-time communication safety
- implement cryptographic measures such as signatures or MACs to protect against integrity attacks, while considering the performance overhead and suitability for the specific OT system

Operational

- regularly test the implemented redundancy and failover mechanisms, e.g. during planned maintenance windows, to ensure they still work when needed

4.5. Next Actionable Steps

- perform a risk assessment to identify potential availability threats and vulnerabilities in OT systems

4.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.
- The BSI Industrial Control System Security: Top 10 threats and countermeasures 2022 contains multiple threats directly related to availability, e.g., “Sabotage”, “(D)DoS attacks”, “Technical failure and force majeure”.

Background information

- PLCs: To Scan or Not to Scan? (youtube, 20.6.2024): presentation analyzing the impact of active scanning as well as OT-specific targeted scanning on PLCs, showing that even benign scans can cause crashes and disrupt availability.

5 Insufficient Access Control

Access Control is a critical aspect of security in any system, but it is especially important in Operational Technology (OT) environments. Insufficient access control can lead to unauthorized access to sensitive systems and data, producing serious consequences for safety and security.

This is an intricate problem that touches on multiple levels of security, including physical, organizational, and technical measures.

5.1. Description

Access Control is the process of restricting access to systems and data to authorized users. Access Control is performed on multiple levels:

- **Organizational**: Organizational access control measures, such as policies and procedures, are designed to ensure that only authorized personnel have access to sensitive systems and data. If an organisation has no written down access matrix (`which employee is allowed to operate what?`), implementing the respective technical access control system is not possible.
- **Technical**: Technical access control measures, such as authentication and authorization mechanisms must be implemented within the used components. This is mostly a topic for system designers and implementors. During operation, these available technical access control measures must be used and enforced by the operators and employees.
- **Physical**: Physical access control measures, such as locks and security guards, are often the first line of defense against unauthorized access in OT environments. However, they are often over-relied upon, leading to a false sense of security.

Particularities of OT

Emergency Situations Access Control and Safety can be conflicting. A good example is the use of emergency stop buttons. In an emergency situation, it is critical that the emergency stop button can be activated quickly and easily. However, this can lead to a situation where unauthorized personnel can also activate the emergency stop button, leading to potential safety hazards.

Another good example are medical devices in hospitals: you do not want to have a password prompt when a doctor wants to use a defibrillator

Legacy Systems Old systems often have only limited security functions. Many (legacy) devices do not support authentication or authorization. As a result, unauthorized access is possible.

Legacy devices often also offer no connection to a central identity management system. This makes it difficult to maintain and respond to changes in the organization's responsibilities on an ongoing basis

Organizational Level

On an organizational level, poorly defined access control can result in "privilege creep," where users accumulate more access than necessary for their job, potentially granting them access to systems and data they should not have.

A well designed access control system should incorporate the following principles:

- **Role-Based Access Control**: Users should be assigned roles based on their job responsibilities. This can help to ensure that users only have access to the systems and data that they need to perform their job and prevents privilege creep, where users accumulate access rights over time.
- **Least Privilege**: Users/roles should only have access to the functions and data they need to perform their job.
- **Separation of Duties**: More than one person is required to perform a task. This should be implemented for critical tasks.
- **Clear Trust Boundaries**: To allow for analysis, trust boundaries have to be defined. This is especially important in the OT world, where the Purdue Model is often used to define trust boundaries.
- **Ongoing Employee Training**: Very often, OT personnel are not aware of the security implications of their actions. This can lead to a situation where a system is not properly secured because the operators do not know how to do it.
- **Deactivating Accounts**: When a user leaves the company, their account should be deactivated.

Implementation Level

- are controls in place? are they well implemented and configured according to best practices?
- given that we want to control access for, e.g., externally reachable adminitrative interfaces (VPN servers, web-panels), are implemented controls sufficient? Having a remote management solution without mandatory and enforced multi-factor authenticator is not state-of-the-art in 2025. Nor was it in 2024. Nor before.
- have default passwords been changed? are there any default accounts that have not been disabled?
- have controls be tested? are they working as intended?
- have physical access control assumptions been documented and tested? It is easier than some people think to get on a factory floor.

- **non-repudiation**: the system should be able to prove who did what. This principle is broken if there's a shared user/password list for devices on the factory floor.

5.2. Rationale

The prevalence of:

- shared password lists
- over-dependency on physical security
- initial attack vector: remote access without multi-factor authentication

5.3. Known Attacks/Examples

- After quitting his job at the plant at the beginning of 2019, he then used the remote login system again on March 27, 2019, to shut down the plant and one of its treatment filters..
- Colonial Pipeline Hack: The attackers gained access to the system by means of a compromised password for a disused VPN account.

5.4. Mitigation/Countermeasures

Design and Implementation

- think about applying zero-trust principles
- define the different systems, how they interacts, and the resulting interfaces (trust boundaries)
- define the roles that are needed to interact with the systems
  - Define a minimal role concept.
  - e.g. on a sensor
    - administrator -> configuration
    - simple user -> only read only access to measuring data
- Implement a role-based access control (RBAC) system
- Implement multi-factor authentication

Operational

- Use the provided features implemented by the vendors
- Change password and default user.
- perform periodic account reviews to counter permission creep
- Implement a process for deactivating accounts when a user leaves the company

5.5. Next Actionable Steps

- Is sensitive information accessible via the available interfaces?
- Is there a role concept for the devices/systems and has this been implemented?

5.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.

Background Information

- ***Physical Access Control***
  - Disabling unnecessary services and protocols
  - Why Disabling unused network ports is crucial in OT environents

6 Missing Incident Detection/Reaction Capabilities

The longer an attacker is able to penetrate the network unnoticed, the higher is the probability that the attacker compromises OT. This also applies if incident reaction is slow or technically inadequate. Without logging and monitoring, breaches cannot be detected. An OT cybersecurity report analysing trends in 2024 shows that 45% of service engagements have a lack of visibility across OT networks, making detections, triage, and response incredibly difficult at scale.

Adversaries may seek to cause Loss of Control, whereby operators are unable to issue commands, even when the malicious interference has subsided.

Another motivation for attackers may be Loss of Productivity and Revenue by disrupting or damaging the availability and integrity of control system operations, devices and related processes.

Furthermore, Loss of Protection leading to the compromise of the functions of protective systems designed to prevent the effects of faults and abnormal conditions may be a motivation. This can result in equipment damage, prolonged process disruption and hazards to personnel.

Finally, Loss of Safety leading to the compromise the functions of safety systems, which are designed to ensure the safe operation of a process when unacceptable or dangerous conditions occur may be a result of a attack. Adversaries may target and disable safety system functions as a prerequisite for subsequent attacks or to allow future unsafe conditions to go unchecked.

6.1. Description

Incident detection and reaction capabilities provide security countermeasures applied when proactive countermeasures did not prevent an attack. The following items introduce vulnerabilities in this category:

- Auditable events, such as logins, failed logins, and executed commands or scripts, are not logged.
- Warnings and errors generate no, inadequate, or unclear log messages.
- Logs of Firmware, OS, applications, and APIs are not monitored for suspicious activity.
- Logs are only stored locally.
- Appropriate alerting thresholds and response escalation processes are not in place or effective.
- Technical security tests (e.g., penetration tests, vulnerability scans, and manual security testing) do not trigger alerts.
- The application cannot detect, escalate, or alert for active attacks in a reasonable short time frame.

6.2. Rationale

Without logging and monitoring, breaches cannot be detected. An OT cybersecurity report analysing trends in 2024 shows that 45% of service engagements have a lack of visibility across OT networks, making detections, triage, and response incredibly difficult at scale.

6.3. Known Attacks

- Ukraine Electric Power Attacks. The Ukraine Electric Power Attack was an operation which aims to target and disrupt transmission and distribution substations within the Ukrainian power grid.
- Triton Safety Instrumented System Attack. The Triton Safety Instrumented System Attack was a campaign that took advantage of the Triton malware framework to target a petrochemical organisation. The malware and techniques employed in this campaign were designed to infiltrate specific Triconex Safety Controllers within the environment. The incident was eventually exposed due to a safety trip that occurred as a result of an issue in the malware.
- LockerGoga ransomware infects industrial and manufactoring companies. In March 2019, Norsk Hydro was subjected to a cyberattack that utilised the LockerGoga ransomware to encrypt its computer files. In response, the aluminium and renewable energy company transitioned to manual operations and maintained transparency with the public regarding its progress towards recovery. The security industry has expressed high regard for Norsk Hydro's transparency throughout the discovery and recovery process.

6.4. Mitigation/Countermeasures

Implement Network Intrusion Prevention. At network boundaries, traffic should be blocked using intrusion detection signatures. When it comes to industrial control environments, network intrusion prevention should be configured so that it will not disrupt protocols and communications responsible for real-time functions related to control or safety.

Design and Implementation

- Ensure all login, access control, and server-side input validation failures can be logged with sufficient user context to identify suspicious or malicious accounts and held for enough time to allow delayed forensic analysis.
- Ensure that logs are generated in a format that log management solutions can easily consume.
- Ensure log data is encoded correctly to prevent injections or attacks on the logging or monitoring systems.

Operational

- Ensure that the generated logs are anlayzed and alerts are triggerd, if an event seems suspicious.
- The implementation of intrusion detection signatures at network boundaries is imperative for the effective prevention of unauthorised access. In the context of industrial control environments, the configuration of network intrusion prevention should be configured in a way that it does not disrupt the protocols and communications that are essential for real-time functions related to control or safety.
- DevSecOps teams should establish effective monitoring and alerting such that suspicious activities are detected and responded to quickly.
- Establish or adopt an incident response and recovery plan, such as National Institute of Standards and Technology (NIST) 800-61r2 or later.

6.5. Next Actionable Steps

- Perform regular incident detection and response exercises where both technical and organizational aspects are tested.
- Example of testing technical aspects: Generate harmless test-malware and place it at an asset on the system under consideration (SUC). Verify, if the upload on that asset is already blocked or at least alarmed. If not, execute the test-malware and place it somewhere else in the SUC. If the upload to the asset is already blocked, encrypt or encode the malware (with several iterations, if needed) and upload it to the asset again to test if host-based detection is also working besides network-based detection.
- Example of testing organizational aspects: Perform a table top exercise simulating an incident or emergency. Test especially communication flows, responsibilities of the staff, coordination of conducting incident response, and the on-demand acquisition of forensic knowledge (if not in-house) during the exercise.

6.6. References

Standards

Applicable standard requirements are listed in the provided mapping table in the appendix.

Background information

- ***Noteable CWSs***: the following Common Weakness Enumeration idenifier are highly relevant to this Top 10 item:
  - CWE-223: Omission of Security-relevant Information. The product fails to record or display information that is essential for identifying the source or nature of an attack, or for assessing whether an action is safe.

  - CWE-532: Insertion of Sensitive Information into Log File. The product logs sensitive information, e.g.; passwords, hashes, or credentials.
  - CWE-778: Insufficient Logging. When a security-critical event occurs, the product either fails to log the event or omits key details in the log.

- ***Notable MITRE ATT&CK framework data sources***: Application Logs are events collected by third-party services, such as mail servers, web applications or other appliances, rather than by the native operating system or platform. Network Traffic is data transmitted across a network (e.g. the web, DNS, email, files, etc.) that is either summarised (e.g. NetFlow) and/or captured as raw, analysable data (e.g. PCAP).

Tooling

- ***Simulating Attacks***: it is highly recommended to verify one's attack detection capabilities. Common approaches are:
  - Eicar malware testfile. The EICAR Anti-Virus Test File, also known as the EICAR Test File, is a computer file developed by the European Institute for Computer Antivirus Research (EICAR) and the Computer Antivirus Research Organisation (CARO) to test how computer antivirus programs respond.
  - Metasploit framework. The Metasploit Framework is a modular, Ruby-based penetration testing platform that allows you to write, test and execute exploit code. It contains a suite of tools for testing security vulnerabilities, enumerating networks, executing attacks and evading detection. At its core, the framework is a collection of commonly used tools that provide a complete environment for penetration testing and exploit development.
- ***Host-centric Logging and Monitoring Tools*** allow for the collection and analysis of logs from individual hosts, such as servers, workstations, and network devices:
  - Graylog is a free SIEM tool enabling central log management.
  - Wazuh is an open source unified XDR and SIEM protection for endpoints and cloud workloads.
- ***Network-centric Logging and Monitoring Tools*** are used to monitor network traffic and detect anomalies or malicious activities:
  - Snort is a open-source intrusion prevention system (IPS). Snort IPS uses a series of rules to help define malicious network activity, identifying packets that match these rules and generating alerts for users. Snort can also be deployed in line to block these packets. Snort has three primary uses: It can be used as a packet sniffer, like tcpdump; as a packet logger, which is useful for debugging network traffic; or as a full-blown network intrusion prevention system. Snort can be downloaded and configured for personal and business use.

- Suricata is a open-source network analysis and threat detection software used by private and public organisations, as well as being embedded by vendors to protect their assets.

7 Broken Zones and Conduits Design

Having a sound segmentation concept mitigates already a lot of other security risks. This makes having proper segmentation and secured interfaces between the segments even more important. On the other hand, a complex design might introduce errors and loopholes in the design. Therefore, the “correct” design is not the most complex, or micro segmented, but the one that fulfills all the needs without being overly complex.

7.1. Description

OT assets (like PLCs, Safety PLCs, HMIs, Historians) should be grouped according to their security requirements in zones. The zones itself can be defined via a risk-based approach (e.g. Threat and Risk Analysis). The objective is to balance operational feasibility (e.g. limited resources) with security considerations (e.g., avoiding overexposure of critical assets). Conduits are controlled communication paths between those zones. Within conduits, communication should be regulated using standard segmentation and segregation controls, such as firewalls and access control lists (ACLs). Segmentation is the process of dividing a network into smaller parts, where the network segments itself should be aligned to the zones defined earlier. Common design errors include:

- Missing demilitarized Zone (DMZ) between IT and OT: Direct connections from IT to OT zones and vice versa are possible without or without proper restriction.
- Overly broad IP and port ranges in access control lists: ACLs are configured with broad IP and port ranges, permitting entire network segments to establish connections across port ranges rather than enforcing per-host restrictions.
- Multi-homed-devices: Multi-homed devices have network interfaces in multiple network zones and may allow lateral movement, either through intentionally enabled routing capabilities or if the device is compromised.
- Possible command and control channels: Protocols such as IMAP and DNS within the OT network introduces the risk of unintended command and control channels, which may be used for lateral movement or data exfiltration.
- Hardware debug interfaces act as backdoors into zones: When debug interfaces like JTAG or SWD are forgotten to be deactivated, they can act as an entry point into otherwise highly secured zones. By gaining access to e.g. a device on the shopfloor via physical access, this enables an attacker to potentially move laterally to other systems in the same zone and compromise it completely.
- Forgotten remote access: While remote access via different protocols and solutions is more or less a necessity in most modern OT environments, they too can act as effective bypasses for defined zone access controls when not considered from the start and isolated

accordingly. By acting as kind of an out-of-bound conduit that was not defined beforehand, this can result in a potential point of entry into a otherwise highly isolated zone.

7.2. Rationale

The most common entry into OT-zones comes from IT environments. For hardware devices the most common entry is via debugging interfaces. After getting entry into the system, without segmenting networks and isolating services, an attacker has full access to the network. Unfortunately, in realty networks are very flat. Segmentation or networks and services enables implementation of core principles like “defense in depth” and “least privilege”.

7.3. Known Attacks/Examples

- Cyber Risk Intelligence: Iran-Linked Attack on U.S.Water Treatment Facility
- Russia-backed hacking group suspected of attack on US water system
- Having e.g., your RDP connections exposed to the internet can have severe consequences as seen with Eternal Blue (What Is EternalBlue and Why Is the MS17-010 Exploit Still Relevant?).

7.4. Mitigation/Countermeasures

Design and Implementation

IEC 62443-3-2 suggests a full methodology for the establishment of zones and conduits. While details can be found there, a short summary should be given at this point:

1. **Identification of the System under Consideration (SuC)**: Identify all systems (hardware and software), network devices and communications links that should be secured by zones and conduits.
2. **Perform an initial cyber security risk assessment**: A high level risk assessment helps in identifying possible threats and worst case risks for the assets in the SuC. This allows prioritization of available resources where they are needed most.
3. **Partition of the SUC into zones and conduits**: Assets are grouped in segments on basis of the results of the initial risk assessment. Further criteria that can influence grouping are criticality of assets, physical and/or logical location, functionality or required access (“Least Privilege”). Conduits are then to be defined between zones. They should be as tightly controlled and minimized as possible.
4. **Check if initial risk exceeds tolerable risk**: If the results of Step 2 exceed the tolerable risk of the organization, an additional detailed risk assessment (Step 5) should be conducted. Otherwise, Step 5 can be omitted.
5. **Perform a detailed cyber security risk assessment**: For each zone and conduit, a more granular threat and risk assessment should be executed. This process should result in

appropriate risk reduction measures and aims to identify any gaps in controls already put in place.

6. **Document cyber security requirements, assumptions and constraints**: All technical requirements for each zone and conduits, all assumptions made during the whole process and all constraints (legacy systems, technological issues, budgetary issues) must be documented for full transparency.
7. **Get asset owner approval**: Owners of affected assets have to review and approve results of the process.

Operational

- Once zones and conduits are implemented, the have to be steadily monitored and reassessed for further improvements and adaptions. Especially network and system changes can require adaptions in the established zoning concept.

7.5. Next Actionable Steps

- Inventorize your assets (including all required interfaces)
- Monitor your networks to get insights in what systems communicate with each other
- Follow the steps outlined above
- For more information, consult IEC 62443-3-2

7.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.

Tooling

- Bloodhound for AD tree building
- nmap for environment scanning
- Network monitoring tools for traffic analysis (especially useful for determination of needed conduits)

8 Missing Awareness

It's not enough to have security capabilities, they need to be used. If no one is aware of potential security issues and how the respective security capabilities can help, employees will not use them and thus finally useless.

8.1. Description

Security awareness is the understanding and knowledge of security risks, threats, and best practices within an organization. It involves educating employees about potential security vulnerabilities and how to mitigate them. In many cases, organizations have security capabilities in place, but employees are not aware of them or do not know how to use them effectively.

There is a connection to Devices with Missing Capabilities: we need both devices with security capabilities and the knowledge to use them. If either is missing, the security capabilities are useless.

The same goes for security policies: if there are policies in place, but they are not lived, they are ultimately useless. This can be due to a lack of knowledge or understanding of the policies, or it can be due to a lack of resources or time to implement them. The best way to counteract this is to make employees understand why the security policies were created and how they protect their daily work.

Add Security Requirements to Tenders

Very often security is an afterthought leading to problems such as insecure designs that are expensive to fix, as well as missing resources for security. This is especially problematic in the OT world with its long-running lifetimes: if security is not part of the design process, fixes can become prohibitively expensive and applying those fixes will lead to downtimes.

A good way to counteract this is to add security requirements to tenders. By including these requirements in tenders, organizations can ensure that security is considered from the outset of the project. Making security tests a part of acceptance tests also gives the "customer" more leverage when negotiating security fixes with the vendor.

OT and IT Are Often Not Integrated

OT and IT are often not integrated, leading to a lack of communication and understanding between the two teams. This can result in security gaps and vulnerabilities that are not addressed.

IT security people often wonder why even basic security hygiene is not applied in OT environments. This can be due to a lack of understanding of the unique challenges and requirements of OT systems. While OT people are in possession of the ground truth, they often wonder why security is now being pushed into their environments.

Many OT systems are designed to operate continuously and cannot be easily patched or updated without causing downtime. This can lead to a culture of "if it ain't broke, don't fix it" that can leave systems vulnerable to attacks.

Security by Obscurity Does Not Work in the Long Run

Security by obscurity is the practice of keeping security measures secret in order to protect them from attackers. This can include using proprietary protocols, custom hardware, or other techniques that are not widely known or understood. The idea is that if attackers do not know how the system works, they will not be able to exploit it.

However, this approach is flawed. Attackers can often reverse-engineer systems or find other ways to discover vulnerabilities, even if the details of the system are not publicly available. Security by obscurity can create a false sense of security and lead to complacency in addressing vulnerabilities.

This approach is often used in OT environments, where systems are not well documented or understood. However, this approach is not effective in the long run, as attackers can still find ways to exploit vulnerabilities.

Security by obscurity can be used to make an attacker's job more difficult, but it should not be relied upon as the sole means of protection.

Security Capabilities Are Useless If Not Used

In OT, we often have the initial problem of long-lived components with missing capabilities, but even if we have the needed capabilities, they are often not used. This can be due to a lack of knowledge or understanding of the capabilities.

Educating employees (in the sense of "explaining the reasons for the measures taken" and not "preaching security") thus is of high importance to ensure that security capabilities are used effectively. This includes providing training and resources to help employees understand how to use security capabilities, as well as creating a culture of security awareness within the organization.

Examples of security problems introduced by missing awareness include:

- everything configuration related
- missing encryption even if available
- available JTAG/SWD interface left enabled on production devices
- Intentional misconfiguration for ease of use, e.g., leaving rtu's in upload mode

Training Beyond Compliance

Training must evolve beyond compliance checkboxes to prepare personnel for real-world scenarios where cyber incidents can appear as equipment failures. The “grey zone” between mechanical failure and cyber attack presents a particular challenge - operators must quickly determine whether they’re facing a component failure or a cyberattack.

Third-Party Blind Spot

A critical gap exists in extending cybersecurity awareness to contractors, vendors, and third-party technicians. These individuals often have privileged access to OT systems but operate with little-to-no cybersecurity awareness. This supply chain vulnerability is increasingly exploited by threat actors, as third parties may have elevated or unrestricted access with far less security training compared to in-house personnel.

8.2. Rationale

The best hardware with the best security capabilities is useless if no one is aware of them and how to use them. Educating employees about security risks and best practices can help mitigate vulnerabilities and improve overall security posture.

8.3. Known Attacks/Examples

- The Register: Iranian hacktivists .. likely broke into the facilities by using default passwords for internet-accessible PLCs
- Colonial Pipeline Hack: The attackers gained access to the system by means of a compromised password for a disused VPN account.
- TRISIS: The Triconex SIS controller had the keyswitch in ‘program mode’ during the time of the attack and the SIS was connected to the operations network against best practices. In a proper configuration and with the controller placed in Run mode (program changes not permitted) the attackers would face a more difficult challenge implementing the attack.

8.4. Mitigation/Countermeasures

Design and Implementation

- capture security requirements in the design process
- explain OT-specific security requirements to software developers (if development is part of the implementation/design process)

Operational

- add security requirements to tenders
- make security tests part of acceptance tests
- create a culture of security awareness
- provide training and resources to employees to help them understand and use security capabilities effectively
- implement security policies and procedures that are easy to understand and follow
- integrate cybersecurity into existing safety programs (HSSE)
- conduct live simulation exercises that test response to ambiguous incidents
- extend training requirements to third-party contractors and vendors before granting access
- develop role-based training tailored to specific operational roles

8.5. Next Actionable Steps

- add security requirements to tenders
- create a culture of security awareness: help employees understand why the security controls taken are important for their work
- provide training and resources to employees to help them understand and use security capabilities effectively
- integrate cybersecurity awareness into existing safety training programs
- implement live simulation exercises for ambiguous incident response

8.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.

Background information

- TRISIS: Analyzing Safety System Targeting Malware (using archive.org)

9 Selection of Components/Protocols With Insufficient Security Capabilities

Given the long, potentially multi-decades, lifetimes of OT system, it becomes understandable why OT components become legacy systems over time. Many of the mentioned countermeasures try to deal with the existence of legacy systems.

When designing new systems, however, the best way to deal with legacy systems is to not use them in the first place. If we design new systems there should be slack for future security features.

This Top 10 items is related to missing awareness. While missing awareness is about the lack of knowledge about security features, this item is about the lack of security features in the first place.

9.1. Description

We define legacy systems as systems with security and cryptography capabilities that do not conform to current best practices. This includes systems that are not able to be updated or patched, as well as systems that are not able to be replaced.

Don't Use Legacy Systems for New Deployments

Obviously, if you are designing a new system, you should not use legacy systems. This is especially true for systems that are not able to be updated or patched. If you are designing a new system, you should use systems that are able to be updated or patched.

Deployments are seldom new green-field installations. Most of the time, new systems are deployed in existing environments (think about the long lifetimes of OT systems). If new components are added to an existing environment, they often have to conform and interact with the existing environment, often mandating usage of legacy protocols. If this is the case, it would be preferable to use components that (while they provide the legacy feature set) also incorporate capabilities for state-of-the-art security features so that the installation can be updated in the future.

Don't Use Legacy Protocols if Possible

Components commonly use standardized protocols to communicate with each other or with other systems. When designing a new system, chosen protocols should heed best security practices and legacy protocols should be avoided if feasible.

Legacy protocols often have security issues:

- They often lack integrity protection and thus can lead to availability problems.
- They do not offer thorough or sufficient authentication mechanisms and thus can lead to unauthorized access to systems and data.
- They have weak built-in security features like basic Bluetooth.

9.2. Rationale

- given the long lifetimes of OT systems, parts of them becoming legacy systems will happen
- there is economic pressure to use existing legacy systems for new deployments:w
- there is a lack of awareness about the security implications of using legacy systems

9.3. Known Attacks/Examples

- Industroyer (also known as CrashOverride) caused the 2016 power outage in Kyiv by speaking the legitimate IEC 60870-5-104, IEC 61850, and OPC DA protocols directly to substation equipment. No vulnerability was needed: IEC 60870-5-104 and IEC 61850 (without the IEC 62351 profiles) provide neither authentication nor integrity protection, so they execute every syntactically valid command from a host that can reach them; OPC DA relies on DCOM authentication, which Industroyer satisfied from an already-compromised host.
- INCONTROLLER (also known as PIPEDREAM) is an attack toolkit discovered in 2022 that abuses legitimate functions of Modbus, CODESYS, and OPC UA to discover, manipulate, and disable Schneider Electric and OMRON Sysmac PLCs and OPC UA servers. It was developed as an offensive capability and, as of CISA AA22-103A, had not been observed deployed in attacks.

9.4. Mitigation/Countermeasures

Design and Implementation

- don't use legacy systems or protocols for new deployments
- use components that are able to be updated or patched
- incorporate some slack for future security features in new designs

Operational

Sadly, there are no operational countermeasures that can be applied to legacy systems. The best way to deal with legacy systems is to not use them in the first place. If you have to use legacy systems, you can try to mitigate the risks by applying the following countermeasures:

- isolate legacy systems from the rest of the network

- monitor legacy systems for unusual activity
- apply compensating controls to mitigate the risks of legacy systems
- apply compensating controls to mitigate the risks of legacy protocols

9.5. Next Actionable Steps

- evaluate the components and protocols used in your systems
- identify legacy systems and protocols in your environment
- evaluate the security capabilities of these systems and protocols
- if possible, replace legacy systems and protocols with state-of-the-art components and protocols
- if replacement is not possible, apply compensating controls to mitigate the risks of legacy systems and protocols

9.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.

10 Missing Hardening

Hardening is usually done to make a system more secure, typically by reducing or restricting features which inherently reduces a system's attack surface. Another form of hardening is enabling additional layers of security so that an attacker has to overcome multiple hurdles to gain access to a system.

10.1. Description

Hardening is the process of securing a system by reducing its surface of vulnerability. This can be achieved by removing unnecessary services, closing unused ports, and applying security patches. Hardening is an essential step in securing any system, as it reduces the number of potential entry points for attackers.

Another way of hardening is to apply additional layers of security, such as firewalls, intrusion detection systems, and encryption. These additional layers can help protect against attacks even if the underlying system is compromised. In the context of OT, hardening is particularly important due to the unique challenges and requirements of these systems. OT systems are often designed to operate continuously and cannot be easily patched or updated without causing downtime.

Apply Established Hardening Guidelines

Hardening guidelines are established best practices for securing systems and networks. These guidelines provide a framework for identifying and mitigating vulnerabilities, and they can help organizations implement effective security measures.

Some well-known hardening guidelines include the Center for Internet Security (CIS) benchmarks or the Defense Information Systems Agency (DISA) Security Technical Implementation Guides (STIGs).

Disable Default Accounts and Passwords

Default accounts and passwords are often used in OT systems, and they can pose a significant security risk if not properly managed. Attackers can easily exploit these default credentials to gain unauthorized access to systems and networks. It is essential to disable or change default accounts and passwords during the hardening process to reduce the risk of unauthorized access.

10.2. Rationale

Inclusion of hardening in the OWASP OT Top 10 was a point of serious discussion.

Hardening itself does not reduce a concrete vulnerability but makes meaningful exploitation of vulnerabilities harder for attackers.

Empirical data, gathered during the development of the OWASP OT Top 10, showed that missing hardening was a common part of successful exploits and comprehensive hardening would have prevented successful exploitation.

Given the requirement of non-stop operation of many OT systems, hardening is crucial as it allows for controlled updates after a security issue has been identified (as the additional security layers uphold the security of the overall system).

10.3. Known Attacks/Examples

- Stuxnet: Disabling USB ports could have avoided initial compromise.
- NotPetya: Proper network segmentation and hardening could have limited the spread of the malware.

10.4. Mitigation/Countermeasures

Mitigation and countermeasures can be applied along the supply chain. Starting from the vendor over the integrator to the asset owner.

Design and Implementation

To ensure robust software security across the development lifecycle, component suppliers, and integrators—must adopt proactive countermeasures:

- Disable unnecessary services and interfaces (e.g. USB ports, insecure protocols like Telnet, web server, JTAG/SWD interfaces)
- Start with established hardening benchmarks and gradually relax controls only as necessary to ensure your component or system functions properly
- Include Application allow-listing if possible
- Provide your component or system with a secure default configuration
- Provide a hardening guideline for your component or system to customers

Operational

Operators play a critical role in maintaining the security and resilience of deployed systems. To reduce risk and ensure operational integrity, the following countermeasures are essential:

- Make sure hardening is reapplied after maintenance
- Request documentation of hardening measures
- Include hardening requirements in the tender, ideally with the integrator providing their own hardening concept
- Make sure hardening is actually implemented with a Pentest or some kind of Cybersecurity Acceptance Test (during SAT/FAT)

10.5. Next Actionable Steps

To be able to implement sensible measures one could follow these steps:

- identify applicable hardening guidelines for your environment: Every environment is different and therefore has different needs and priotitizes different topics. Finding the right measures for the system under consideration is the first and most crucial step when trying to improve the security posture of a system.
- implement hardening guidelines: After identifying the shortcomings, hardening guidelines for the insecure systems can help to provide a good baseline to improve from.
- disable default accounts and passwords: Default credentials are commonly used and misused way of getting access to permissions that should normally be behind proper safeguards.

10.6. References

Standards

- Applicable standard requirements are listed in the provided mapping table in the appendix.
- OT-specific hardening guides are often provided by the system integrator or product supplier, for example:
  - *"System Hardening for Substation Automation and Protection"* for SICAM/SIPROTEC, which includes hardening measures at the solution level as well as for individual components.
- Several organizations provide configuration baselines and benchmarks for common systems:
  - The **Center for Internet Security (CIS)** offers **Benchmarks** for various systems, including operating systems, network devices, and commonly used applications. In OT environments, relevant benchmarks cover operating systems, network infrastructure, and supporting applications.
  - The **Defense Information Systems Agency (DISA)** publishes **Security Technical Implementation Guides (STIGs)**, which define configuration standards for securing Department of Defense (DoD) IT systems and are also widely adopted in other

sectors.

- **Microsoft Security Baselines** recommend security settings for Windows operating systems and Microsoft applications.

Background information

- BSI IT-Security in der Industrie (german)
- https://en.wikipedia.org/wiki/Hardening_(computing)
- https://en.wikipedia.org/wiki/Defense_in_depth_(computing)

Tooling

- Tenable Nessus / OpenVAS, with compliance Scanning
- Microsoft Security Compliance Toolkit

Part IV

Where to Start



What's next and Where to Start?

So basically, you've read through the Top 10 list and are now wondering how to best proceed from here. This is a common question, and we want to help you get started.

There's an `actionable next steps` section within each Top 10 item. This should give you a good idea what are suitable next steps for you. This can be a bit overwhelming, so we want to give you a bit of additional high-level guidance.

For existing Systems

So you already have a system in place and are now wondering how to improve it. After going through the Top 10 list, you either feel a bit insecure about your current situation or you have identified some areas that need improvement. This is a good thing, as it means you are aware of the issues and can now start working on them.

On the other hand, you might feel overwhelmed by the amount of work that needs to be done. This is also a common feeling.

Using a continously improvement approach can help you to not get overwhelmed and to make steady progress (while being aligned to common ISO/IEC standards). Here are some steps you can take:

1. Don't panic. We would love to have green-field systems but we have to work and improve with what we're currently working with.
2. Assess your situation. You can use the list of `actionable next steps` from the Top 10 items for this.
3. Select low-hanging fruits and improve them, maybe combine updates into your existing maintenance cycle
4. Go back to step 2

For new Systems/Components

If you are in the process of designing a new system or component, you have the advantage of being able to start with security in mind from the very beginning. This is often referred to as "security by design".

If you are currently in progress of buying a new system or component:

- add security requirements to your tenders and incorporate some slack for future updates
- do not select protocols/components with known security issues. If insecure protocols are currently mandatory (due to existing components that the new component must interact with), select components that additionally offer secure protocols so that you will have an upgrade path in the future

Prepare for Incidents

Incidents will happen, no matter how well you prepare. The best you can do is to be prepared for them. This includes:

- Create incident response plans and perform readiness training. You will be stressed out during an incident and want to have good plans and routines to fall back to.
- Foster a security culture within your organization. This is a long-term process, but it will pay off in the end. Make sure that everyone is aware why security is important for their respective tasks instead of mandating security top-down.
- talk with your vendors/suppliers about their security practices and how they handle incidents. This will help you to understand their capabilities and how they can support you in case of an incident.

Additional Reading

- NIS Factsheet
- NIST CSF 2.0

Part V

About the Project



About OWASP

The Open Worldwide Application Security Project (OWASP) is an open community dedicated to enabling organizations to develop, purchase, and maintain applications and APIs that can be trusted.

At OWASP, you'll find free and open:

- Application security tools and standards
- Cutting edge research
- Standard security controls and libraries
- Complete books on application security testing, secure code development, and secure code review
- Presentations and videos
- Cheat sheets on many common topics
- Chapters meetings
- Events, training, and conferences

All OWASP tools, documents, videos, presentations, and chapters are free and open to anyone interested in improving application security.

We advocate approaching application security as a people, process, and technology problem, because the most effective approaches to application security require improvements in these areas.

OWASP is a new kind of organization. Our freedom from commercial pressures allows us to provide unbiased, practical, and cost-effective information about application security.

OWASP is not affiliated with any technology company, although we support the informed use of commercial security technology. OWASP produces many types of materials in a collaborative, transparent, and open way.

The OWASP Foundation is the non-profit entity that ensures the project's long-term success. Almost everyone associated with OWASP is a volunteer, including the OWASP board, chapter leaders, project leaders, and project members. We support innovative security research with grants and infrastructure.

Community and Contributing

Please don't hesitate to contact the OWASP OT Top 10 project with your questions, comments, and ideas, either publicly by adding issues or providing commits on our github page.

Please join the OWASP OT Top 10 Slack Channel to chat. You can get a free invitation to the OWASP slack server through this website.

We do a video conference every first Monday of the month from 4pm to 5pm CET/CEST using https://meet.google.com/gwi-vhxz-rjr. We also provide a public ICS calendar series that you can add to your calendar.

How to Contribute?

All development is public and happens on github. If you want to contribute, please fork the repository, make your changes, and then submit a pull request. We will review your changes and provide feedback as needed.

If you plan a larger change, it is always a good idea to talk with us during one of the Monthly meetings first. This way we can discuss your ideas and provide feedback before you start working on the changes. This can save you a lot of time and effort, and it can also help us to ensure that your changes are aligned with the goals of the project.

You find the source code of the current version of the OWASP OT Top 10 in the `docs/` directory within the git repository. When you check our open issues on github, you can see that some issues are tagged with `help wanted` or `good first issue`. Choose these if you want to help out the project!

Empirical Data Contribution

The OWASP OT Top 10 are created by both discussions with experts as well as through analysis of empirical data (e.g., incident reports, vulnerability databases, etc.). We are looking for empirical data that can help us to identify the most relevant risks and vulnerabilities in the OT domain. This includes data from incident reports, vulnerability databases, and other sources that can provide insights into the security landscape of OT systems.

If you have empirical data that you would like to contribute, please contact us through email (Andreas Happe). If you are able to contribute data, please make sure that it is appropriately anonymized.

How to Test Your Changes Locally Before Submitting

If you can run python, you can locally run the OWASP OT Top 10 website locally. We recommend this to test your changes before pushing them to github.

To do this, we will use `venv` to create a local python environment to install the needed `mkdocs` package.

```
# creates and activates a new python environment in a new `venv`
 ↪  directory
$ python3 -m venv venv
$ source venv/bin/activate

# install the mkdocs package
$ pip install mkdocs-material

# switch into your checked-out OWASP OT Top 10 directory
$ cd owasp-ot-top10

# run the local webserver
$ mkdocs serve

# now you can point your browser to http://localhost:8000 and check
# how your changes will look like
```

List of Our Contributors

The OT Top 10 wouldn't be possible without our awesome contributors and reviewers. We use the GitHub contributors feature to automatically track contributions to the repository. Here is a list of our main contributors:

Contributor	Company	Connect through
Andreas Happe		LinkedIn
Siegfried Hollerer	Federal Ministry of the Interior, Austria	LinkedIn
Simon Rommer	OMICRON electronics	LinkedIn
Felix Eberstaller	Limes Security	
Nino Fürthauer	Limes Security	
Sixtus Leonhardsberger	Limes Security	
mfd2007		
Marleine van Kampen		
Mariia D.		

Related OWASP Projects

OWASP is a volunteer-driven organization. Those volunteers contributed many useful documents, and this section points to some related OWASP documents and projects:

OWASP IoT Top 10

The increasing introduction of IoT devices in OT environments (Industrial IoT, IIoT) comes with many of the security problems that are known from common IoT. This makes OWASP IoT Top 10 a valuable resource especially for suppliers and integrators, but for operators as well.

In OT we often analyze whole factory floors or power plants, situating our list of Top 10 vulnerabilities on a higher conceptional level. In addition, OT is burdened with long lifetimes and problematic update cycles placing a greater importance on defense-in-depth measures like good network segregation.

(I)IoT is a part of OT, but OT is broader in scope and utilized IoT devices within. This difference in scope is reflected in the Top Vulnerability list: when using the IoT Top 10, only 2 out of the 10 top vulnerabilities directly map onto the OT domain (I4 and I5).

OWASP hosts multiple projects that aim to increase the security of IOT projects.

OWASP Top 10

The best known OWASP standard, the Top 10 of web application security, is also relevant for OT. Suppliers and integrators developing software in form of web applications, e.g. for control systems with a web interface can find useful information on how to avoid the most common vulnerabilities in web applications – even when they are used in an industrial environment.

In contrast, this document is focused on defensive techniques and controls as opposed to risks. Each control in this document will map to one or more items in the risk-based OWASP Top 10. This mapping information is included at the end of each control description.

Part VI

Appendix



Mapping table

The following tables map each OWASP OT top 10 item to relevant standard and legislative requirements.

1. Unknown Assets and Unmanaged External Access

Standard/Law	Requirement-IDs
IEC 62443	FR 2
IEC 62443-2-1:2019	CM 1, NET 3.X
IEC 62443-3-2:2020	ZCR 1, ZCR 3.6
IEC 62443-3-3:2020	SR 2.X, SR 7.8
NIST SP 800-82:v3	CM-8, AC-20, AC-17, CM-2
NIST CSF 2.0	ID.AM, PR.AA, PR.IR-01
MITRE ATT&CK	M0800, M0801, M0804, M0807, M0813, M0918, M0922, M0926, M0932
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	6.7, 11.X, 12.1, 12.2, 12.4

2. Devices with known Vulnerabilities/Issues

Standard/Law	Requirement-IDs
IEC 62443	FR3, FR4
IEC 62443-3-2:2020	ZCR 5.2
IEC 62443-3-3:2020	SR 3.X, SR 4.X
NIST SP 800-82:v3	SI-2, RA-5, CM-6
NIST CSF 2.0	ID.RA-01, ID.IM, PR.PS, DE.CM-09
MITRE ATT&CK	M0916, M0934, M0942, M0945, M0948
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	6.5, 6.6, 6.10

3. Inadequate Supplier/Supply Chain Management

Standard/Law	Requirement-IDs
IEC 62443-2-1:2019	ORG 1.6
IEC 62443-3-2:2020	ZCR 5.X
NIST SP 800-82:v3	SR-2, SR-3, SR-5, SR-6
NIST CSF 2.0	GV.OC-03, GV.OC-04, GV.OC-05, GV.SC, ID.RA-10
MITRE ATT&CK	M0817
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	5.X, 6.1, 6.2

4. Loss of Availability

Standard/Law	Requirement-IDs
IEC 62443	FR 7
IEC 62443-2-1:2019	DATA 1.3, DATA 1.4, SPE 8
IEC 62443-3-3:2020	SR 7.X
NIST SP 800-82:v3	CP-2, CP-7, CP-9, CP-10
NIST CSF 2.0	GV.OC-04, GV.OC-05, GV.SC-07, GV.SC-08, PR.AA-02, PR.IR-02, PR.IR-03, PR.IR-04, DE.CM, RC.RP-01, RC.RP-02, RC.RP-04
MITRE ATT&CK	M0803, M0811, M0812, M0815, M0953
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	4.X, 6.4, 13.1, 13.2

5. Insufficient Access Control

Standard/Law	Requirement-IDs
IEC 62443	FR 1, FR 2
IEC 62443-2-1:2019	SPE 2
IEC 62443-3-3:2020	SR 1.X, SR 2.X
NIST SP 800-82:v3	AC-2, AC-3, AC-6, AC-5
NIST CSF 2.0	ID.IM-01, ID.IM-03, PR.AA, PR.PS-05, PR.IR-01

Standard/Law	Requirement-IDs
MITRE ATT&CK	M0800, M0801, M0804, M0807, M0813, M0918, M0922, M0926
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	6.7, 11.X, 13.3

6. Missing Incident Detection/Reaction Capabilities

Standard/Law	Requirement-IDs
IEC 62443	FR 6
IEC 62443-2-1:2019	ORG 2.2, SPE 7
IEC 62443-3-2:2020	ZCR 5.1, SR 6.X
NIST SP 800-82:v3	IR-4, SI-4, AU-6, IR-6
NIST CSF 2.0	GV.SC-08, ID.IM-04, DE.CM, DE.AE, RS.X
MITRE ATT&CK	M0919, M0931
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	3.X

7. Broken Zones and Conduits Design

Standard/Law	Requirement-IDs
ISO27001 Annex	A.8.22
IEC 62443	FR 5
IEC 62443-2-1:2019	SPE 3
IEC 62443-3-2:2020	ZCR 3.X, SR 5.X
NIST SP 800-82:v3	SC-7, AC-4, SC-2
NIST CSF 2.0	ID.IM, PR.IR-01
MITRE ATT&CK	M0930, M0935, M0937
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	6.7, 6.8

8. Missing Awareness

Standard/Law	Requirement-IDs
IEC 62443-2-1:2019	ORG 1.4
IEC 62443-3-3:2020	SR 7.6, SR 7.7
NIST SP 800-82:v3	AT-2, AT-3
NIST CSF 2.0	PR.AT
MITRE ATT&CK	M0917
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	8.1, 8.2, 12.5

9. Insufficient Security Capabilities

Standard/Law	Requirement-IDs
IEC 62443-2-4:2024	SP.03.03
IEC 62443-3-2:2020	ZCR 5.X
IEC 62443-4-2:2020	CCSC 2
NIST SP 800-82:v3	PM-1, CA-2, CA-7
NIST CSF 2.0	ID.RA-01, ID.IM, PR.AA-02, PR.PS-01, PR.PS-02, PR.PS-03, PR.PS-06
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	6.3, 6.5, 6.10, 12.2

10. Missing Hardening

Standard/Law	Requirement-IDs
IEC 62443-2-1:2019	ORG 1.5
IEC 62443-2-1:2024	COMP 1.1
IEC 62443-2-4:2024	SP.02.03
IEC 62443-3-3:2024	X
IEC 62443-4-1:2018	SG-3
IEC 62443-4-2	X
NIST SP 800-82:v3	CM-6, CM-7, SI-3, SC-28
NIST CSF 2.0	PR.PS

Standard/Law	Requirement-IDs
MITRE ATT&CK	M0806, M0818, M0921, M0924, M0927, M0928, M0934, M0936, M0938, M0942, M0944, M0949, M0950, M0951, M0954
EU NIS2 Directive Commission implementing Regulation C(2024) 7151 - ANNEX	6.3, 6.9, 9, 12.3

Glossary

Asset An **asset** refers to any physical or digital component that plays a role in the operation, control, or monitoring of industrial processes. These assets are critical to the functioning of systems in sectors like manufacturing, energy, transportation, and utilities.

Awareness (Security) **Awareness** refers to the knowledge and understanding that individuals within an organization have about potential security threats and the behaviors required to prevent or respond to them. It's a critical component of an organization's overall cybersecurity strategy.

BSI The **B**undesamt für **S**icherheit in der **I**nformationstechnik, or Federal Office for Information Security—is Germany's central authority for cybersecurity and information security.

CIS The **C**enter for **I**nternet **S**ecurity and its CIS Controls—a set of best practices to secure systems, including industrial environments like SCADA and ICS.

CNC **C**omputer **N**umerical **C**ontrol machines are automated tools used in manufacturing for tasks like drilling, milling, and cutting.

Contributors A **contributor** is someone who adds value to a project, organization, or effort by providing work, ideas, resources, or support. This can include writing, coding, designing, funding, or offering expertise.

CVE A **C**ommon **V**ulnerabilities and **E**xposures is a publicly disclosed cybersecurity vulnerability with a unique identifier.

cyber attacks A **cyber attack** is a deliberate attempt by an adversary to damage, disrupt, or gain unauthorized access to computer systems, networks, or data.

cyber physical system A **C**yber-**P**hysical **S**ystem is a system that integrates computing, networking, and physical processes.

DCS A **D**istributed **C**ontrol **S**ystem is an automated control system used in industrial environments to manage processes.

DISA The **D**efense **I**nformation **S**ystems **A**gency is a U.S. Department of Defense (DoD) agency that provides secure, reliable IT and communications support to military operations.

FAT A **F**actory **A**cceptance **T**est is a quality assurance process conducted at the manufacturer's site to verify that equipment or systems meet the required specifications before delivery.

Hardening (System) **hardening** is the process of securing a system by reducing its attack surface.

HMI A **H**uman-**M**achine **I**nterface is a user interface that allows humans to interact with machines, systems, or devices.

HVAC HVAC stands for **H**eating, **V**entilation, and **A**ir **C**onditioning—a system used to regulate indoor climate and air quality.

IDS An **I**ntrusion **D**etection **S**ystem is a cybersecurity tool that monitors network or system activity for signs of malicious behavior or policy violations.

IEC IEC stands for the **I**nternational **E**lectrotechnical **C**ommission, a global organization that develops and publishes international standards for electrical, electronic, and related technologies.

IEC62443 IEC 62443 is a series of international standards focused on cybersecurity for industrial automation and control systems (IACS).

ISO27001 ISO/IEC 27001 is an international standard for managing information security (management systems).

IT **I**nformation **T**echnology refers to the use of computers, networks, and software to manage and process information.

NERC-CIP **N**orth **A**merican **E**lectric **R**eliability **C**orporation – **C**ritical **I**nfrastructure **P**rotection is a set of mandatory cybersecurity standards designed to protect the Bulk Electric System (BES) in North America.

NIDS A **N**etwork **I**ntrusion **D**etection **S**ystem is a security tool that monitors network traffic for suspicious activity or known threats.

NIS NIS stands for **N**etwork and **I**nformation **S**ystems Directive, a European Union regulation aimed at improving cybersecurity across critical infrastructure sectors.

NIST The **N**ational **I**nstitute of **S**tandards and **T**echnology, a U.S. federal agency that develops standards, guidelines, and best practices for science, technology, and cybersecurity.

OT **O**perational **T**echnology refers to hardware and software systems that monitor and control physical devices, processes, and infrastructure.

OWASP OWASP stands for the **O**pen **W**orldwide **A**pplication **S**ecurity **P**roject, a nonprofit organization focused on improving software security.

SAT A **S**ite **A**cceptance **T**est is a process used to verify that a system or equipment functions correctly in its actual operating environment.

SCADA **S**upervisory **C**ontrol and **D**ata **A**cquisition, a system used to monitor and control industrial processes remotely.

Segmentation Network **segmentation** is the practice of dividing a computer network into smaller, isolated segments or subnets. This improves security, performance, and manageability by controlling traffic flow and limiting access between segments.

SIS **S**afety **I**nstrumented **S**ystems are automated systems designed to prevent hazardous events in industrial processes by taking a process to a safe state when predetermined conditions are violated.

STIG A **S**ecurity **T**echnical **I**mplementation **G**uide is a set of cybersecurity configuration standards developed by the Defense Information Systems Agency (DISA). STIGs are used primarily by the U.S. Department of Defense (DoD) and affiliated organizations to secure IT systems, software, and networks against cyber threats.

Supply chain A **supply chain** is the network of people, organizations, resources, activities, and technologies involved in the creation and delivery of a product or service from the supplier to the customer.

Vulnerabilities A **vulnerability** is a weakness or flaw in a system, software, or network that can be exploited by a threat actor to gain unauthorized access, cause damage, or disrupt operations.



The OWASP Operational Technology Top 10

ot.owasp.org

Licensed under Creative Commons Attribution-ShareAlike 4.0 International. OWASP® is a registered trademark of the OWASP Foundation, Inc.